

UNIVERSIDAD DISTRITAL
FRANCISCO JOSÉ DE CALDAS

Segundo Taller

Mecanismos de seguridad Informática

Juan David Orduz Sastoque (20221020096), Jhojan Aragon Ramirez (20221020060), Yader Ibraldo Quiroga Torres (20222020034), y Arlo Nicolas Ocampo Gallego (20221020104)

Ingeniería de Sistemas, Facultad de Ingeniería

Universidad Distrital Francisco José de Caldas

Mecanismos de Seguridad

14 de noviembre de 2026

Bogotá, D.C.

Nota del Autor

Trabajo académico desarrollado en un laboratorio aislado y autorizado. Las pruebas se realizan con equipos propios o máquinas virtuales, direcciones privadas y tráfico de prueba; no se genera tráfico hacia Internet, redes institucionales en producción ni direcciones de terceros.

Índice

Introducción **5**

Parte I. Análisis de casos **7**

1. Presentación y alcance **7**

2. Objetivos **7**

3. Resultados de aprendizaje **8**

4. Topología y reglas del laboratorio **8**

5. Herramientas sugeridas **9**

6. Casos críticos de trabajo **10**

6.1. Caso 1. TCP SYN Flood: indisponibilidad y agotamiento de conexiones 12

6.2. Caso 2. DNS tunneling: posible salida encubierta mediante UDP/53 22

6.3. Caso 3. Exposición de servicios HTTP, FTP y otros servicios heredados 25

6.4. Caso 4. Detección de anomalías con IA/ML en tráfico TCP/IP 37

6.5. Caso 5. TCP: resets inesperados e indicios de inyección o desincronización 40

Ficha de registro del hallazgo. Caso 5 45

6.6. Caso 6. UDP: reflexión/amplificación DNS, NTP o SSDP 45

6.7. Caso 7. ICMP: escaneo, payloads atípicos y posible túnel 48

6.8. Caso 8. Escaneo de puertos y fingerprinting de servicios 57

6.9. Caso 9. Priorización y correlación de alertas con IA y SIEM 65

6.10. Caso 10. Mensajería XMPP: interceptación y errores de TLS 68

7. Formato mínimo de registro por hallazgo **78**

8. Entregables de la Parte I **79**

8.1. Criterios de calidad del informe 80

Parte II. Programación **80**

9. Descripción y alcance de la solución **80**

9.1. Alcance propuesto 81

9.2. Fuera de alcance 81

10. Requisitos funcionales **82**

11. Requisitos técnicos **83**

11.1. Aplicación móvil 83

11.2. Bot en Telegram (opcional) 83

11.3. Backend y API REST 84

11.4. Mapa y visualización 84

11.5. Requisitos de seguridad y privacidad 85

12. Arquitectura de referencia **85**

13. Modelo de datos propuesto **86**

14. Plan de trabajo **87**

15. Entregables de la Parte II **87**

16. Consideraciones éticas, legales y de privacidad **88**

16.1. Principios de tratamiento 88

16.2. Prohibiciones explícitas 89

16.3. Matriz de riesgos éticos y legales 89

17. Conclusiones **89**

17.1. Conclusiones de la Parte I 90

17.2. Conclusiones de la Parte II 90

17.3. Limitaciones y trabajo futuro 90

Anexos **92**

Anexo A. Registro de evidencias y cadena de custodia 93

Anexo B. Lista de verificación de entrega 94

Anexo C. Glosario 94

Introducción

Este documento es la plantilla de trabajo del **Segundo Taller de Mecanismos de Seguridad**. Reúne, en un solo informe técnico, el análisis de diez casos de seguridad en redes IEEE 802.3 con servicios TCP/IP y el diseño de una solución de programación para el rastreo autorizado de ubicaciones. El taller se desarrolla en un laboratorio académico aislado, con equipos propios o máquinas virtuales, direcciones privadas y tráfico de prueba.

La plantilla está dividida en archivos independientes para facilitar el trabajo en equipo, la revisión por pares y el control de versiones. Cada integrante puede trabajar en su archivo sin sobrescribir el de sus compañeros; al final, todos los archivos se ensamblan en `main.tex`.

Tabla 1
Organización de la plantilla

Archivo	Contenido
`main.tex`	Preámbulo, portada, metadatos y ensamblado del documento.
`secciones/01-introduccion.tex`	Introducción, alcance, nota ética y datos del equipo.
`secciones/02-marco-parte1.tex`	Presentación, objetivos, resultados de aprendizaje, topología, reglas y herramientas.
`secciones/03-casos/`	Diez fichas de caso, una por archivo.
`secciones/04-registro-hallazgos.tex`	Formato mínimo de registro y consolidado de hallazgos.
`secciones/05-entregables-parte1.tex`	Entregables y lista de verificación de la Parte I.
`secciones/06-parte2-descripcion.tex`	Descripción y alcance de la solución de rastreo.
`secciones/07-parte2-requisitos.tex`	Requisitos funcionales, técnicos y de seguridad.
`secciones/08-parte2-arquitectura.tex`	Arquitectura de referencia, modelo de datos y plan de trabajo.
`secciones/09-parte2-etica.tex`	Consideraciones éticas, legales y de privacidad.
`secciones/10-conclusiones.tex`	Conclusiones y recomendaciones.
`secciones/11-anexos.tex`	Registro de evidencias, lista de entrega y glosario.
`referencias.bib`	Fuentes bibliográficas en formato BibLaTeX (APA 7).

Cómo usar la plantilla

- Reemplace los marcadores `Integrante 1`, `Integrante 2`, `Integrante 3` e `Integrante 4` de la portada por los nombres y códigos reales.

- Complete la Tabla 2 con los datos del equipo y la distribución de responsabilidades.
- Desarrolle cada caso en su archivo correspondiente. No elimine las preguntas de análisis: responda cada una con evidencia.
- Adjunte capturas de pantalla legibles, filtros de Wireshark, extractos de registros y, cuando aplique, el archivo PCAP de laboratorio.
- Calcule el hash SHA-256 de cada evidencia original y regístrelo en la ficha del caso y en el Anexo A.
- Verifique que todas las direcciones, nombres y credenciales estén anonimizados antes de entregar el informe.
- Cierre el documento con las conclusiones, las limitaciones de la evidencia y las referencias consultadas.

Alcance ético y legal

Este taller es un ejercicio académico. No se solicita vulnerar, atacar ni hackear sistemas, redes o personas reales. Todas las actividades de análisis se realizan sobre capturas didácticas, telemetría sintética o pruebas benignas autorizadas en un entorno aislado. El rastreo de ubicaciones de la Parte II debe operar únicamente con consentimiento informado, finalidad académica y datos anonimizados; no se permite rastrear personas sin autorización ni reutilizar la información para fines distintos de los del taller.

Datos del equipo

Tabla 2
Integrantes del equipo y distribución de responsabilidades

No.	Nombre completo	Código	Responsabilidad principal
1			
2			
3			
4			

Distribución sugerida. Una distribución equilibrada consiste en asignar los casos 1 a 3 al Integrante 1; los casos 4 y 5, junto con el backend de la Parte II, al Integrante 2; los casos 6 a 8 y la aplicación móvil al Integrante 3; y los casos 9 y 10, junto con el bot de Telegram y la integración, al Integrante 4. Todos los integrantes deben revisar la versión final y firmar la lista de verificación del Anexo B.

Parte I. Análisis de casos

1. Presentación y alcance

La práctica estudia riesgos de disponibilidad, confidencialidad e integridad en una LAN Ethernet IEEE 802.3 que transporta IPv4/IPv6 y servicios TCP/IP. El trabajo se realiza exclusivamente en equipos propios o máquinas virtuales, con direcciones privadas, tráfico de prueba y autorización expresa. No se debe generar tráfico hacia Internet, redes institucionales en producción ni direcciones de terceros.

El alcance del informe comprende el análisis de diez casos críticos, la propuesta de controles preventivos, detectivos, correctivos y de recuperación, y el diseño de una solución de programación para el rastreo autorizado de ubicaciones. Los controles se contrastan con las recomendaciones para sistemas de detección y prevención de intrusiones (Scarfone & Mell, 2007) y para el endurecimiento de servidores (Scarfone et al., 2008). Cada afirmación técnica debe sostenerse en evidencia verificable: capturas, registros, filtros, comandos, hashes y marcas de tiempo.

2. Objetivos

- Reconocer indicadores de compromiso y comportamientos anómalos en tráfico TCP, UDP, ICMP, DNS, HTTP/HTTPS y mensajería.
- Usar Wireshark y registros del sistema para correlacionar eventos, direcciones, puertos, marcas de tiempo y estados de conexión.
- Evaluar controles preventivos y detectivos: firewall, segmentación, endurecimiento de servicios, TLS, limitación de tasa e IDS/SIEM.
- Proponer el uso responsable de aprendizaje automático para priorizar alertas, sin delegar bloqueos

automáticos críticos a un modelo no validado.

- Documentar resultados reproducibles mediante capturas, filtros, registros, hashes y recomendaciones verificables.
- Diseñar, en la Parte II, una propuesta técnica y ética de una aplicación, programa o bot que permita compartir y visualizar ubicaciones con consentimiento informado.

3. Resultados de aprendizaje

- Diferencia entre síntoma, indicador, hipótesis y evidencia confirmada.
- Interpreta capturas de paquetes y registros sin confundir anomalías con prueba definitiva de ataque.
- Relaciona cada caso con controles preventivos, detectivos, correctivos y de recuperación.
- Entrega un informe técnico con hallazgos, limitaciones y un plan de mejora priorizado.

4. Topología y reglas del laboratorio

La topología sugerida es un ejemplo; se pueden usar direcciones privadas equivalentes, siempre que la red permanezca aislada y bajo control del equipo.

Tabla 3
Elementos de la topología sugerida

Elemento	Dirección / función	Recomendación
Switch Ethernet IEEE 802.3	VLAN de laboratorio	Sin conexión a la red productiva.
Equipo analista	192.168.50.10/24	Wireshark; acceso a los registros del laboratorio.
Servidor web/pruebas	192.168.50.20/24	HTTP de laboratorio o HTTPS con certificado de prueba.
Servidor DNS de laboratorio	192.168.50.53/24	Resolver solo nombres de prueba.
Servidor de mensajería (opcional)	192.168.50.30/24	XMPP en entorno aislado.
Gateway de laboratorio	192.168.50.1/24	Sin reenvío hacia Internet; filtrado habilitado.

En este trabajo se mantuvo el esquema sugerido, pero se utilizó el segmento `172.28.50.0/24` sobre una red Docker puente con la opción `internal: true`, de modo que los contenedores no tuvieran salida a Internet. El equipo analista se ubicó en `172.28.50.10` y los servidores de pruebas

en `172.28.50.20`, `172.28.50.30` y `172.28.50.31`. La Figura 1 muestra la topología efectivamente desplegada.

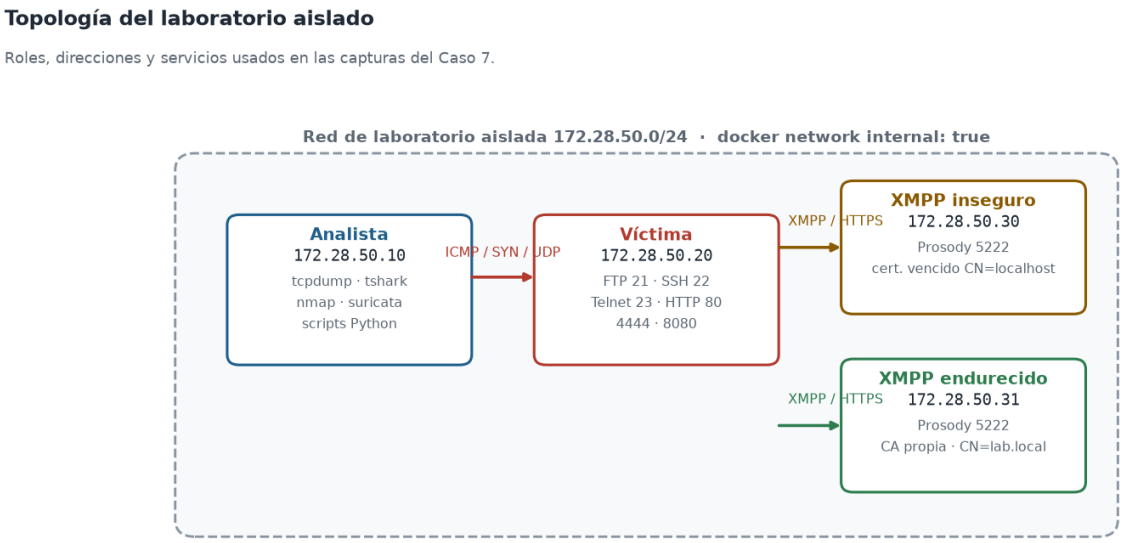


Figura 1
Topología del laboratorio

Reglas obligatorias.

- Usar exclusivamente equipos o máquinas virtuales bajo control del grupo y una VLAN o red virtual aislada.
- Generar tráfico de prueba benigno o utilizar PCAP didácticos o sintéticos. Ejecutar pruebas de DoS, exfiltración o spoofing únicamente en ambientes aislados y con autorización.
- Sincronizar los relojes de los equipos y registrar fecha, hora, IP, puerto, herramienta y versión.
- Anonimizar datos personales y credenciales; no capturar tráfico de usuarios ajenos al laboratorio.
- Guardar una copia original de cada evidencia y calcular su hash SHA-256; analizar una copia de trabajo.

5. Herramientas sugeridas

Se sugiere Wireshark; `netstat` y PowerShell en Windows; el Visor de eventos; Windows Defender Firewall; Zeek y/o Suricata cuando estén disponibles; Wazuh o un SIEM equivalente; y

Python con scikit-learn para el análisis de características agregadas (Scikit-learn developers, 2026; Wireshark Foundation, 2026). Utilice herramientas y versiones aprobadas para el laboratorio y registre la versión exacta en cada ficha.

Tabla 4
Herramientas del laboratorio y registro de versiones

Herramienta	**Uso en el taller**	**Versión registrada**
Wireshark / TShark	Captura, filtrado y análisis de tráfico.	4.2.5
`tcpdump`	Captura de paquetes en el laboratorio aislado.	4.99.4
Nmap	Escaneo de puertos y detección de servicios.	7.95
Suricata	Detección de intrusiones y validación de reglas.	7.0.7
OpenSSL	Inspección de certificados y pruebas TLS.	3.3.7
Prosody	Servidor XMPP de laboratorio.	0.11.9
Python y Scapy	Generación de tráfico y análisis automatizado.	3.12.13 / 2.6.1
Docker Engine y Compose	Contenedores y red aislada del laboratorio.	29.8.0 / v5.5.1
`netstat` y PowerShell	Estado de conexiones, procesos y servicios.	Windows 11
Visor de eventos y Defender Firewall	Registros del sistema y validación de filtrado.	Windows 11

6. Casos críticos de trabajo

En cada caso, el equipo debe completar las tareas de observación y análisis, justificar los indicadores, proponer controles y adjuntar evidencia. Las actividades de ataque se sustituyen por análisis de PCAP, telemetría sintética o pruebas benignas autorizadas. La Tabla 5 presenta el panorama de los diez casos.

Tabla 5

Resumen de los casos críticos

Caso	Tema	Protocolo / servicio	Evidencia principal
1	TCP SYN Flood	TCP	Gráfica temporal SYN/ACK y tabla de conexiones.
2	DNS tunneling	UDP/53, DNS	Consultas filtradas y tabla por host/dominio.
3	Servicios HTTP, FTP y heredados	HTTP, FTP, otros	Inventario de servicios y matriz de riesgo.
4	Detección de anomalías con IA/ML	TCP/IP	Notebook reproducible y métricas del modelo.
5	Resets TCP e indicios de inyección	TCP	Tabla de flujos afectados y extractos de logs.
6	Reflexión y amplificación UDP	DNS, NTP, SSDP	Gráficas de paquetes y bytes por segundo.
7	ICMP: escaneo, payloads y túnel	ICMP	PCAP de línea base, barrido y túnel; reglas Suricata validadas.
8	Escaneo de puertos y fingerprinting	TCP/UDP	PCAP de escaneo SYN, servicios y UDP; lista de exposición.
9	Priorización de alertas con IA y SIEM	Múltiples fuentes	Pipeline y ejemplo de alerta enriquecida.
10	Mensajería XMPP y errores de TLS	XMPP, TLS	PCAP XMPP/HTTPS, checklist TLS y alerta de certificado.

6.1. Caso 1. TCP SYN Flood: indisponibilidad y agotamiento de conexiones

Situación

Un servidor web de laboratorio responde lentamente o deja de aceptar nuevas conexiones.

Objetivo:

Analizar el comportamiento del establecimiento de conexiones TCP para identificar posibles indicadores de un ataque SYN Flood, mediante la inspección de paquetes de red, el análisis de conexiones y la revisión de registros del sistema.

Se busca identificar patrones anormales en las solicitudes SYN, respuestas SYN/ACK y confirmaciones ACK, así como proponer mecanismos de detección y mitigación que contribuyan a proteger la disponibilidad de los servicios de red.

Fundamento Teórico:

TCP (Transmission Control Protocol) es un protocolo de transporte orientado a conexión que utiliza un proceso de establecimiento conocido como Three-Way Handshake.

Este proceso consta de tres etapas:

- SYN: el cliente solicita establecer una conexión.
- SYN/ACK: el servidor responde aceptando la solicitud.
- ACK: el cliente confirma la respuesta y se completa el establecimiento de la conexión.

Un ataque SYN Flood busca agotar los recursos del servidor mediante el envío de numerosas solicitudes SYN que pueden quedar sin completar. Esto puede provocar una acumulación de conexiones pendientes y afectar la disponibilidad del servicio.

Procedimiento: El análisis forense y de tráfico se llevó a cabo siguiendo una serie de pasos secuenciales respaldados por las evidencias capturadas:

1. **Preparación y verificación de la captura PCAP:**

   Se verificó la integridad del archivo de captura utilizado mediante el cálculo de su huella criptográfica SHA-256 en entorno PowerShell, obteniendo el valor hash correspondiente al

archivo analizado, como se observa en la Figura 2.

2. **Identificación de paquetes SYN mediante Wireshark:**

   Se cargó el archivo `200722_tcp_anon.pcapng` en la herramienta Wireshark y se aplicó el filtro de visualización `tcp.flags.syn == 1 && tcp.flags.ack == 0` para aislar las solicitudes de inicio de conexión puras (paquetes SYN), identificando las tramas correspondientes (Figura 3).

3. **Identificación de respuestas SYN/ACK:**

   Se aplicó el filtro `tcp.flags.syn == 1 && tcp.flags.ack == 1` para localizar las respuestas del servidor aceptando las conexiones solicitadas (Figura 4).

4. **Inspección del establecimiento de conexiones y Handshake:**

   Mediante el filtro `tcp.flags.ack == 1 && tcp.flags.syn == 0`, se examinaron los paquetes de confirmación ACK y el flujo posterior de la comunicación, incluyendo intercambio de datos y cierre de sesión (Figura 5).

5. **Inspección de conversaciones TCP:**

   Se utilizó la herramienta de estadísticas de conversaciones TCP de Wireshark para analizar los flujos de comunicación entre las direcciones IP involucradas (Figura 6).

6. **Análisis temporal de solicitudes y respuestas:**

   Se emplearon las gráficas de E/S (*I/O Graphs*) de Wireshark configurando filtros específicos para tramas SYN (Figura 7) y SYN/ACK (Figura 8) con el fin de evaluar la distribución temporal del tráfico.

7. **Inspección de conexiones TCP locales:**

   Se revisó el estado de las conexiones de red del sistema mediante comandos de diagnóstico para evaluar los estados actuales de los sockets (Figura 9).

```
PS C:\WINDOWS\System32>  Get-FileHash "$HOME\Documents\GitHub\segundo-taller-mecanismos-seguridad\Capturas PCAP\Originales\200722_tcp_anon.pcapng" -Algorithm SHA256

Algorithm       Hash                                                                   Path
---------       ----                                                                   ----
SHA256          5295B16EA117FA8BB1A65418FCA81E709BEA58D3A830BC3BB5C4A2ED0466EA9C       C:\Users\Juan Orduz\Documents...
```

Figura 2

Verificación de integridad del archivo PCAP mediante el cálculo de hash SHA-256.

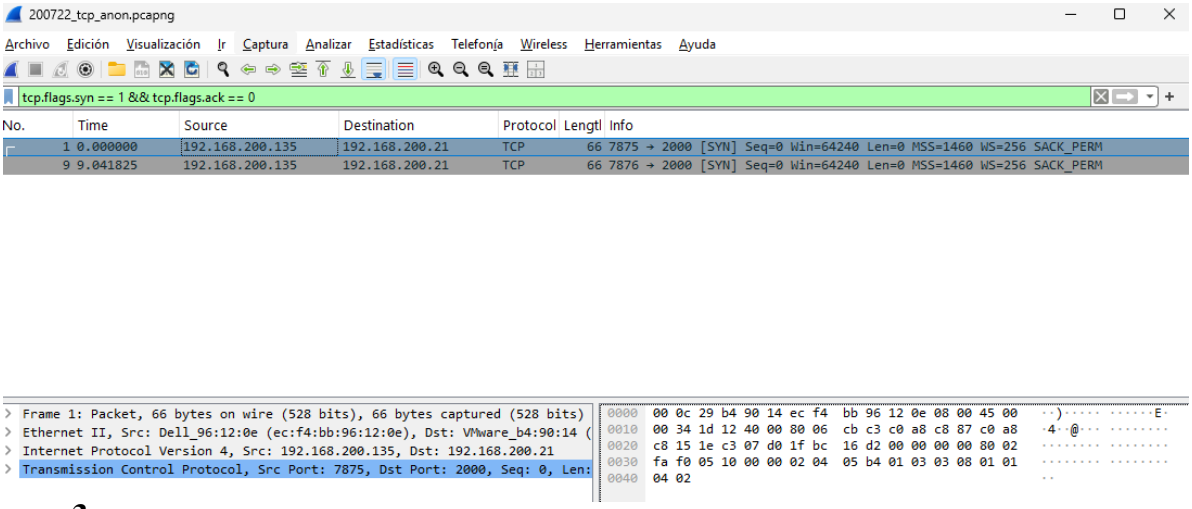


Figura 3

Filtrado de solicitudes de inicio de conexión SYN (`tcp.flags.syn == 1 && tcp.flags.ack == 0`) en Wireshark.

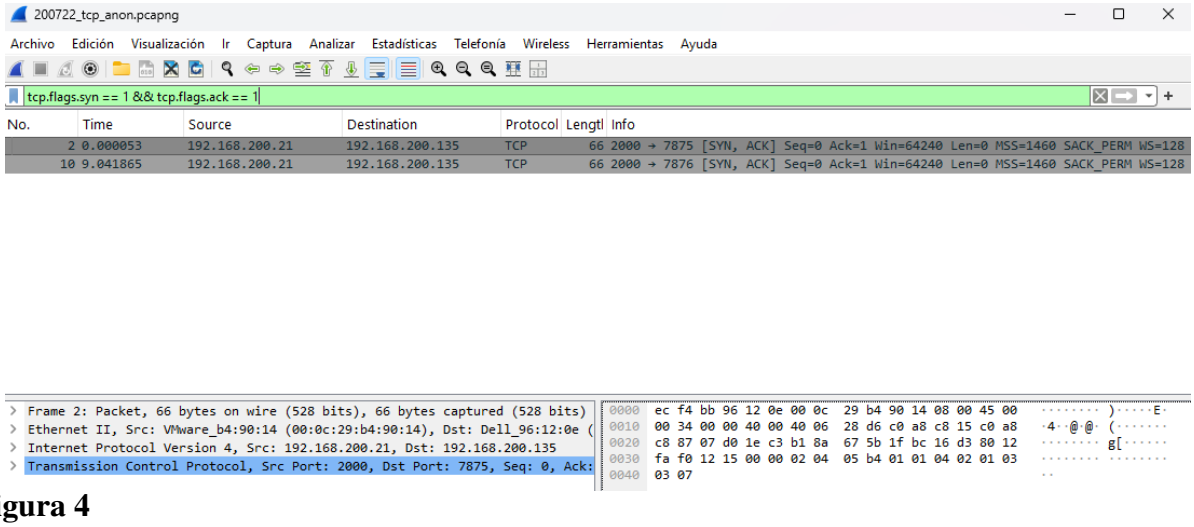


Figura 4

Identificación de respuestas SYN/ACK del servidor (`tcp.flags.syn == 1 && tcp.flags.ack == 1`).

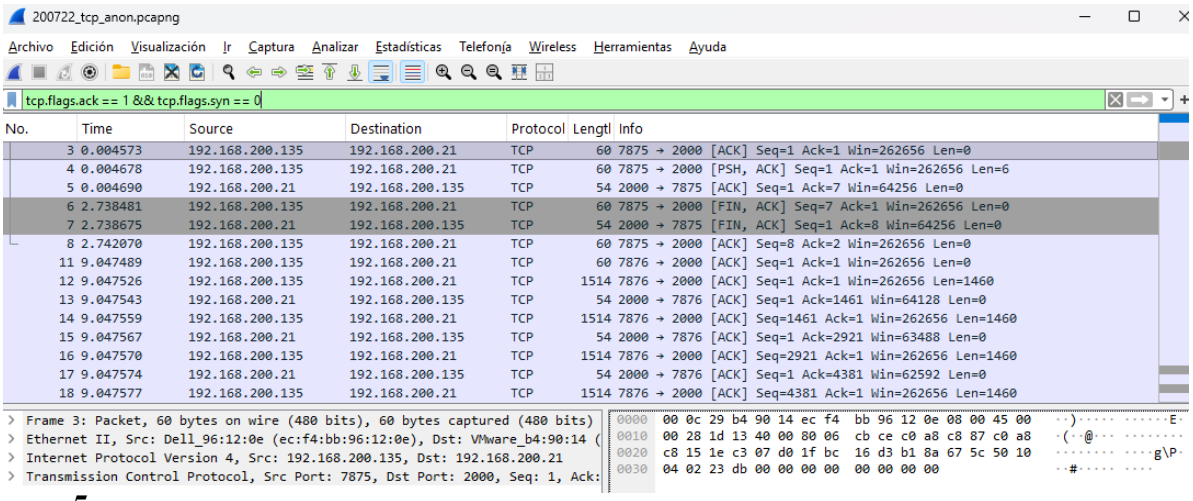


Figura 5

Inspección de paquetes ACK y tráfico posterior de la sesión TCP.

Resultados obtenidos: A partir de la inspección de las evidencias proporcionadas por las capturas de Wireshark y las herramientas del sistema, se extrajeron los siguientes resultados cuantitativos y cualitativos:

- **Análisis de paquetes SYN y SYN/ACK:** En las capturas de Wireshark se identificaron explícitamente dos solicitudes SYN principales (tramas 1 y 9) originadas desde la dirección IP `192.168.200.135` (puertos `7875` y `7876`) dirigidas al servidor `192.168.200.21` en el puerto `2000` (Figura 3). Asimismo, el servidor respondió simétricamente con dos paquetes SYN/ACK (tramas 2 y 10) hacia los mismos puertos de origen (Figura 4).

- **Conversaciones TCP:** Las estadísticas de conversaciones TCP (Figura 6) reflejan los flujos de comunicación identificados en la captura:

- **Estados de conexión locales:** La inspección mediante comandos de red (Figura 9) muestra múltiples conexiones activas asociadas a procesos del sistema, reportando predominantemente estados como `Established`, además de estados de cierre y espera como `TimeWait` y `CloseWait`, con identificadores de proceso (`OwningProcess`) numéricos específicos (ej. `14244` y `24444`).

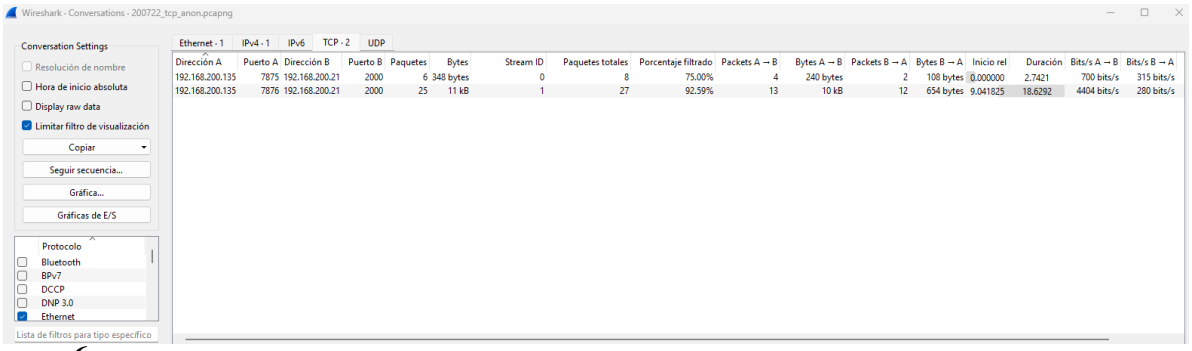


Figura 6

Estadísticas de conversaciones TCP recopiladas en Wireshark.

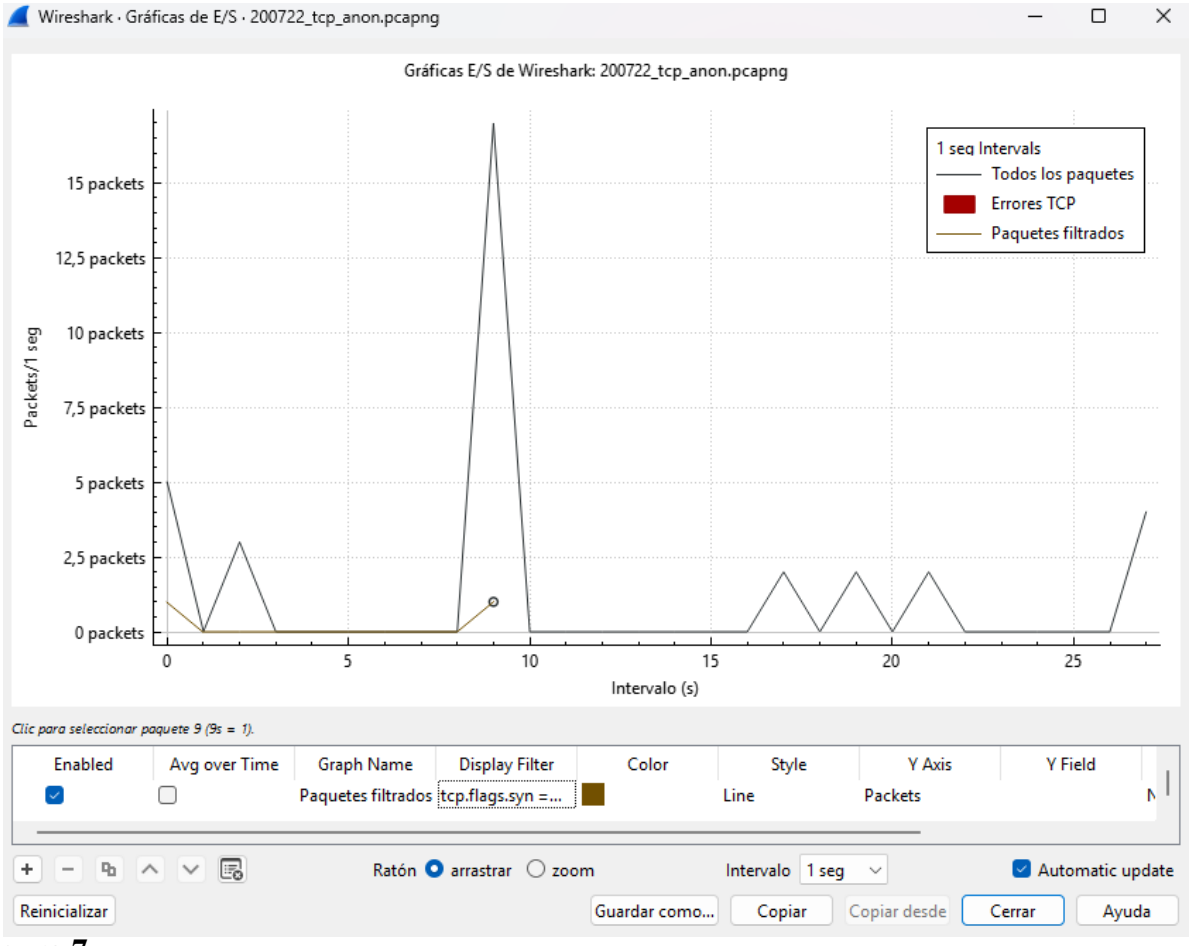


Figura 7

Gráfica de E/S de Wireshark para el análisis temporal de paquetes SYN filtrados.

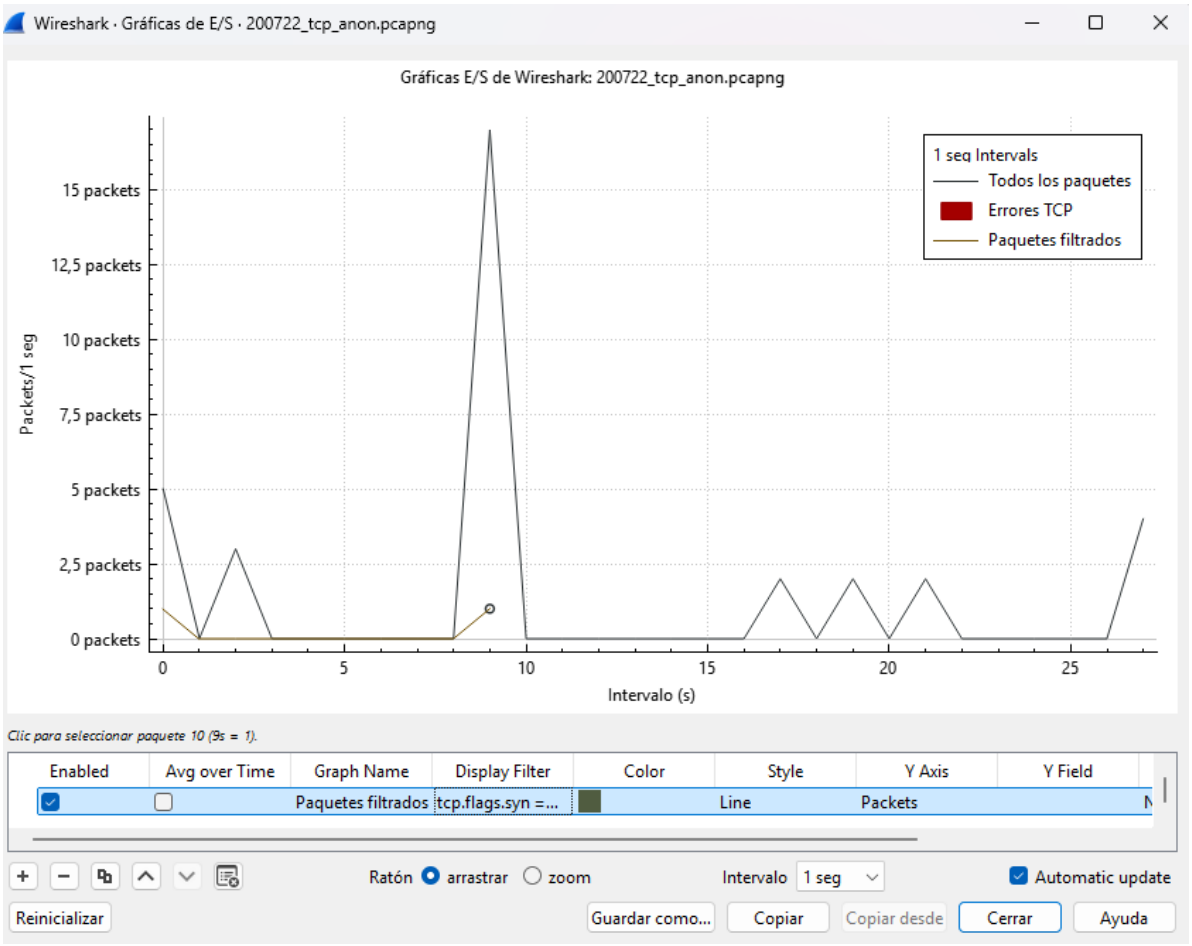


Figura 8

Gráfica de E/S de Wireshark para el análisis temporal de respuestas SYN/ACK.

Tabla 6

Tabla de conversaciones TCP extraídas de la evidencia.

IP Origen	Puerto A	IP Destino	Puerto B	Paquetes Totales	Bytes Totales	Duración (s)
192.168.200.135	7875	192.168.200.21	2000	8	348 bytes	2.7421
192.168.200.135	7876	192.168.200.21	2000	27	11 kB	18.6292

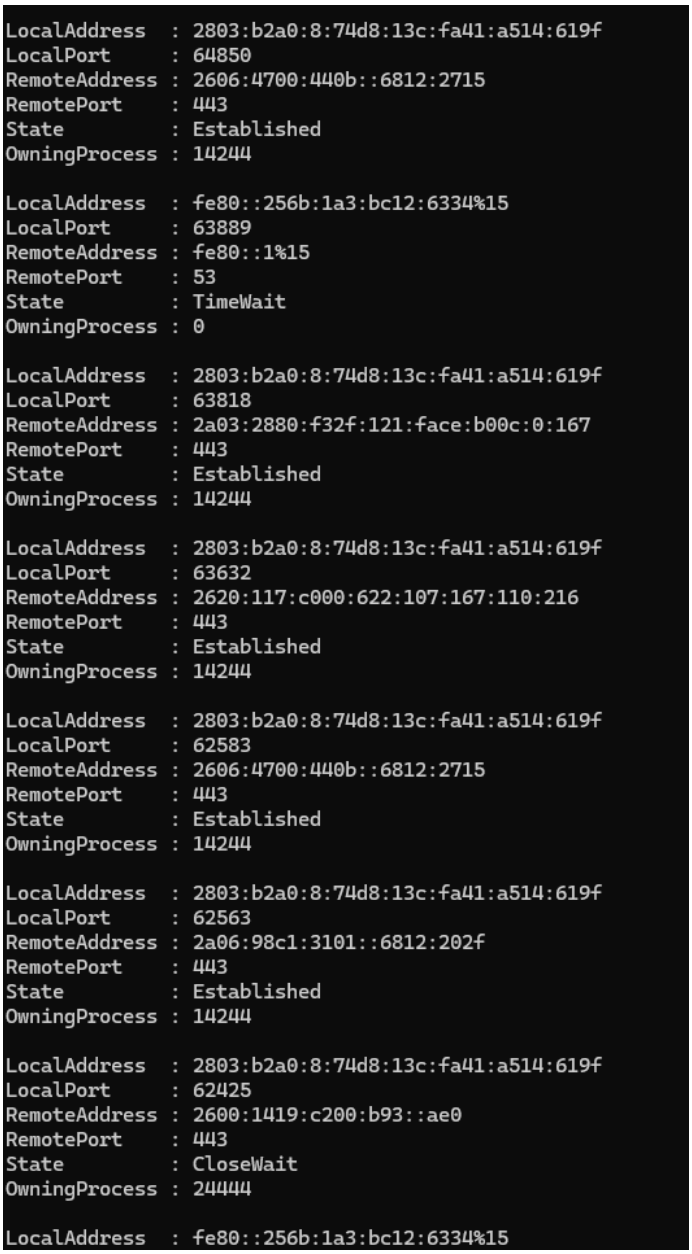


Figura 9

Inspección de estados de conexiones de red locales mediante comandos de diagnóstico.

Análisis de resultados: Al contrastar las evidencias obtenidas, se observa un comportamiento normal y completado del *Three-Way Handshake* para las conexiones analizadas. Cada paquete SYN enviado por el cliente (`192.168.200.135`) obtuvo una respuesta SYN/ACK correspondiente por parte del servidor (`192.168.200.21`), seguida de los paquetes ACK correspondientes que permitieron establecer la comunicación y realizar transferencia de datos (como se visualiza en las tramas de la Figura 5 y las duraciones registradas en la Tabla 6).

Si bien las gráficas temporales de E/S (Figuras 7 y 8) muestran un pico puntual de tráfico que alcanza aproximadamente 17 paquetes por segundo en el intervalo de los 9 segundos, este incremento responde a una ráfaga legítima de intercambio de datos y cierre de conexiones, y no a una acumulación masiva de solicitudes SYN huérfanas.

Limitaciones de las evidencias: Las trazas analizadas corresponden a un escenario de tráfico controlado con un volumen reducido de transacciones entre IPs específicas; por lo tanto, las evidencias no muestran síntomas de saturación, agotamiento de recursos ni un ataque SYN Flood activo.

Indicadores de detección: A partir del análisis de las evidencias, se evalúan los siguientes indicadores de seguridad:

- **Picos de solicitudes SYN:** Observado puntualmente en la gráfica temporal (Figura 7), pero asociado a tráfico legítimo.
- **Solicitudes SYN sin completar el handshake:** No observado; todas las solicitudes contaron con su respectiva respuesta y confirmación.
- **Incremento de conexiones pendientes:** No verificado en las capturas analizadas.
- **Múltiples fuentes generando solicitudes:** No observado, el tráfico proviene de una única IP cliente (`192.168.200.135`).

- **Comportamiento temporal inusual:** Se detectó un pico temporal aislado a los 9 segundos, el cual fue verificado como parte de la transferencia normal de la sesión (Figura 6).

Regla de detección propuesta: Para la identificación temprana de anomalías de tipo SYN Flood en entornos de producción, se propone una regla conceptual basada en umbrales dinámicos respecto a la línea base del servicio:

$$\text{Alerta SYN Flood} \iff \left(\frac{\text{Conteo SYN}_{\Delta t}}{\text{Conteo SYN/ACK}_{\Delta t}} > \alpha\right) \wedge \left(\text{Conexiones}_{\text{Half-Open}} > \text{Umbral}_{\text{baseline}}\right)$$

Donde α representa el factor de proporción esperado entre solicitudes de establecimiento y respuestas del servidor, y los umbrales numéricos deben calibrarse estrictamente de acuerdo con el comportamiento histórico y la capacidad de procesamiento del servicio protegido.

Mitigación y defensa. Para garantizar la resiliencia de la infraestructura ante posibles escenarios de denegación de servicio por agotamiento de conexiones, se recomiendan las siguientes medidas técnicas:

- **Actualización de sistemas:** Mantener actualizados el sistema operativo y los servicios expuestos para parchear vulnerabilidades de pila de red.
- **Limitación de exposición:** Reducir la superficie de ataque limitando el acceso a los servicios únicamente a redes o segmentos autorizados.
- **Mecanismos de protección nativos:** Habilitar tecnologías de mitigación a nivel de sistema operativo como *SYN Cookies* para evitar el consumo de memoria en la cola de conexiones pendientes (*backlog*).
- **Control de tasa (*Rate Limiting*):** Aplicar políticas de control de tráfico en los dispositivos de borde o cortafuegos para limitar ráfagas excesivas de solicitudes SYN.
- **Monitorización continua:** Vigilar activamente el estado de las colas de conexiones y escalar incidentes al equipo de infraestructura ante anomalías sostenidas.

Es indispensable validar que la implementación de estas medidas no restrinja ni bloquee el acceso a los clientes legítimos de la red.

Preguntas de análisis.

1. **¿Qué recursos mantiene el servidor durante el handshake TCP?**

   Durante el proceso de establecimiento de conexión (*Three-Way Handshake*), el servidor web reserva recursos críticos en su pila de red. Al recibir una solicitud SYN, el núcleo del sistema operativo asigna una entrada en la cola de conexiones pendientes (*SYN backlog queue*) y crea una estructura de control de socket (*Transmission Control Block - TCB*), consumiendo memoria RAM y ciclos de procesamiento para gestionar los temporizadores de retransmisión y los números de secuencia iniciales hasta recibir la confirmación ACK final.

2. **¿Qué falsos positivos pueden producir picos legítimos?**

   Un incremento repentino en la tasa de solicitudes SYN no siempre denota actividad maliciosa. Entre los factores legítimos que pueden generar picos temporales se encuentran: la concurrencia masiva de usuarios en horarios pico, el inicio simultáneo de aplicaciones cliente, reintentos automáticos de conexión ante intermitencias temporales de la red, la ejecución de actualizaciones de software o la apertura múltiple de conexiones persistentes de tipo HTTP/2 o HTTP/3 por parte de navegadores modernos.

Conclusiones:

- Se logró analizar exitosamente el contenido del archivo de captura PCAP mediante la verificación de su integridad criptográfica y la inspección detallada de tramas en Wireshark.
- Se identificó un comportamiento TCP completamente normal y estructurado mediante el *Three-Way Handshake*, donde las solicitudes SYN enviadas por la IP `192.168.200.135` obtuvieron respuestas SYN/ACK y confirmaciones ACK válidas por parte del servidor `192.168.200.21`.

- No fue posible comprobar la existencia de indicadores de un ataque SYN Flood debido a que el volumen de tráfico analizado es reducido y no presenta conexiones huérfanas ni desproporción entre solicitudes y respuestas.
- El análisis presentó limitaciones derivadas de la naturaleza acotada de la muestra de tráfico de laboratorio, la cual carece de escala masiva.
- Se determinó la pertinencia de implementar mecanismos defensivos preventivos, tales como *SYN Cookies* y políticas de control de tasa, para proteger la disponibilidad futura ante eventuales contingencias de denegación de servicio.

Tabla 7
Ficha de registro del hallazgo. Caso 1

Campo	**Registro**
Identificador	Caso 1 (TCP SYN Flood), Evidencias 01 a 08 (`01_hash_original.png` a `08_conexiones_netstat.png`). Analista: Juan David Orduz.
Fecha y hora	Captura analizada: `200722_tcp_anon.pcapng` (datos anonimizados del 20 de julio de 2007).
Origen/destino	Tráfico observado entre el cliente `192.168.200.135` (puertos `7875`, `7876`) y el servidor `192.168.200.21` (puerto `2000`).
Observación	Análisis forense de tráfico de red en Wireshark y revisión de conexiones locales mediante consola. Se identificó un establecimiento de conexión TCP normal (*Three-Way Handshake*) sin evidencias de ataque SYN Flood.
Hipótesis	Si el servidor experimenta un ataque SYN Flood, se observará una desproporción masiva de paquetes SYN frente a SYN/ACK y una acumulación de conexiones semiconectadas (*half-open*).
Validación	Las capturas y estadísticas de Wireshark (Figuras 3 a 8) y de red (Figura 9) mostraron simetría total en el *handshake*, descartando anomalías de denegación de servicio.
Severidad	Baja / Informativa (Escenario de laboratorio con tráfico nominal controlado).
Acción	Documentar los resultados técnicos reales, descartar la hipótesis de ataque por falta de indicadores y proponer directrices de monitorización preventiva y mitigación.
Integridad	Archivo de captura validado mediante huella criptográfica SHA-256 (`5295B16EA117FA8BB1A65418FCA81E709BEA58D3A830BC3BB5C4A2ED0466EA9C`).

6.2. Caso 2. DNS tunneling: posible salida encubierta mediante UDP/53

Situación

Se observa tráfico DNS con consultas repetitivas o nombres de dominio inusualmente largos. El DNS se define en el RFC 1035 (Mockapetris, 1987).

Procedimiento.

- Aplicar en Wireshark el filtro `udp.port == 53` y, cuando corresponda, `dns`.
- Examinar la longitud y la entropía aproximada de las etiquetas, la frecuencia, el volumen por cliente y los dominios consultados.
- Correlacionar con el resolver autorizado y los registros DNS; usar únicamente dominios de prueba o PCAP de entrenamiento.

Indicadores que deben buscarse. Subdominios largos o de alta entropía, alta frecuencia, respuestas o tamaños atípicos y destinos no habituales; verificar explicaciones legítimas como telemetría o CDN.

Mitigación y defensa. Forzar el uso de resolvers autorizados; registrar las consultas; aplicar filtrado DNS y políticas de salida; investigar el host de origen antes de bloquear.

Evidencias que se entregan. Capturas filtradas, tabla por host/dominio, hipótesis y verificación con registros.

Preguntas de análisis.

1. ¿Por qué el carácter sin conexión de UDP no significa que todo DNS sea malicioso?
2. ¿Qué atributos ayudan a distinguir una anomalía?

Tabla 8

Ficha de registro del hallazgo. Caso 2

Campo	**Registro**
Identificador	
Fecha y hora	
Origen/destino	
Observación	
Hipótesis	
Validación	
Severidad	
Acción	
Integridad	

6.3. Caso 3. Exposición de servicios HTTP, FTP y otros servicios heredados

Situación

El servidor presenta servicios abiertos que podrían estar innecesarios o débilmente configurados. Los riesgos de aplicaciones web se pueden contrastar con el catálogo OWASP (OWASP Foundation, 2021).

Objetivo:

Identificar y evaluar los servicios de red en un entorno de laboratorio mediante el inventario de puertos, versiones y configuraciones de seguridad. A través de este análisis, se busca detectar vulnerabilidades, protocolos inseguros o software desactualizado para proponer mitigaciones efectivas que reduzcan la superficie de exposición y protejan la infraestructura de posibles riesgos.

Fundamento Teórico:

Los servicios de red permiten el intercambio de recursos mediante protocolos y puertos específicos, pero cada puerto abierto constituye un punto de exposición cuyo riesgo real depende de su configuración, versión de software y controles de acceso. Mientras que protocolos tradicionales como HTTP (puerto 80) y FTP (puerto 21) transmiten información y credenciales sin cifrar, sus alternativas seguras como HTTPS (puerto 443) y SFTP (puerto 22) emplean cifrado para garantizar la integridad y confidencialidad de los datos. La identificación y evaluación de estos servicios, junto con otros protocolos heredados e inseguros, es fundamental para determinar su necesidad operativa y corregir configuraciones vulnerables en la infraestructura.

Procedimiento. Las actividades desarrolladas durante la práctica comprendieron:

1. **Inventario de servicios y puertos:** Se examinó el estado de los puertos TCP en escucha mediante comandos de red del sistema operativo, correlacionándolos con la lista de servicios instalados (Figuras 10 y 11).

2. **Identificación de servicios, versiones y propietarios:** Se asociaron los puertos activos con sus respectivos identificadores de proceso (PID) y servicios del sistema para determinar las

dependencias operativas y ejecutores (Figura 12).

3. **Comprobación autorizada de exposición:** Se realizaron pruebas de conectividad de alcance limitado hacia puertos específicos mediante utilidades de red nativas para verificar la accesibilidad local y el filtrado de interfaces (Figura 13).

4. **Revisión de registros de autenticación y eventos:** Se consultaron los registros de eventos de seguridad del sistema operativo para identificar intentos de inicio de sesión o anomalías de acceso (Figura 14).

5. **Verificación de cifrado y mínimo privilegio:** Se inspeccionaron las cuentas de ejecución asignadas a los servicios del sistema para evaluar el cumplimiento del principio de mínimo privilegio y el uso de credenciales de servicio (Figura 15).

6. **Evaluación de riesgos y propuesta de mitigación:** Se integraron las evidencias para ponderar la exposición de la infraestructura y estructurar recomendaciones de endurecimiento.

LocalAddress	LocalPort	State	OwningProcess
::	49677	Listen	1564
::	49668	Listen	4588
::	49667	Listen	3084
::	49666	Listen	1676
::	49665	Listen	1444
::	49664	Listen	1616
::1	42050	Listen	27256
::	33060	Listen	6228
::	7680	Listen	21812
::	5432	Listen	6964
::	3306	Listen	6228
::	445	Listen	4
::	135	Listen	1876
127.0.0.1	57539	Listen	15984
127.0.0.1	53005	Listen	2916
127.0.0.1	53000	Listen	2916
127.0.0.1	51100	Listen	19844
127.0.0.1	50100	Listen	17140
127.0.0.1	50085	Listen	13188
0.0.0.0	49677	Listen	1564
0.0.0.0	49668	Listen	4588
0.0.0.0	49667	Listen	3084
0.0.0.0	49666	Listen	1676
0.0.0.0	49665	Listen	1444
0.0.0.0	49664	Listen	1616
127.0.0.1	27339	Listen	4
127.0.0.1	22112	Listen	17804
127.0.0.1	13032	Listen	17140
127.0.0.1	13031	Listen	17140
127.0.0.1	13030	Listen	17804
127.0.0.1	11001	Listen	4964
127.0.0.1	9013	Listen	22916
127.0.0.1	9012	Listen	22916
127.0.0.1	6850	Listen	20580
127.0.0.1	6463	Listen	12200
0.0.0.0	5432	Listen	6964
0.0.0.0	5040	Listen	9512
0.0.0.0	1236	Listen	4896
127.0.0.1	1042	Listen	13256
192.168.101.16	139	Listen	4
172.31.144.1	139	Listen	4
0.0.0.0	135	Listen	1876

Figura 10

Inventario de puertos TCP en estado de escucha y procesos asociados.



Name	DisplayName
ADPSvc	Servicio de plataforma de datos agregados
ALG	Servicio de puerta de enlace de nivel de aplicación
AMD Crash Defender Service	AMD Crash Defender Service
AMD External Events Utility	AMD External Events Utility
AmdAppCompatSvc	AMD Application Compatibility Database Service
AmdPpkgSvc	AMD Provisioning Packages Service
AppIDSvc	Identidad de aplicación
Appinfo	Información de la aplicación
AppReadiness	Preparación de aplicaciones
AppXSvc	AppX Deployment Service (AppXSVC)
ApxSvc	Servicio de proxy de dispositivo de audio virtual de Windows
ArmouryCrateService	Armoury Crate Service
asus	ASUS Update Servicio (asus)
AsusCertService	ASUS Certificate Service
AsusFanControlService	AsusFanControlService
asusm	ASUS Update Servicio (asusm)
AsusROGLSLService	AsusROGLSLService Download ROGLSLoader
AsusUpdateCheck	AsusUpdateCheck
AudioEndpointBuilder	Compilador de extremo de audio de Windows
Audiosrv	Audio de Windows
Aura Wallpaper Service	Aura Wallpaper Service
autotimesvc	Hora de la red de telefonía móvil
AxInstSV	Instalador de ActiveX (AxInstSV)
BDESVC	Servicio Cifrado de unidad BitLocker
BFE	Motor de filtrado de base
BITS	Servicio de transferencia inteligente en segundo plano (BITS)
BrokerInfrastructure	Servicio de infraestructura de tareas en segundo plano
BTAGService	Servicio de puerta de enlace de audio de Bluetooth
BthAvctpSvc	Servicio AVCTP
bthserv	Servicio de compatibilidad con Bluetooth
camsvc	Servicio Administrador de funcionalidad de acceso
CDPSvc	Servicio de plataforma de dispositivos conectados
CertPropSvc	Propagación de certificados
ClickToRunSvc	Microsoft Office Click-to-Run Service
ClipSVC	Servicio de licencias del cliente (ClipSVC)
com.docker.service	Docker Desktop Service
COMSysApp	Aplicación del sistema COM+
CoreMessagingRegistrar	CoreMessaging
CryptSvc	Servicios de cifrado
DcomLaunch	Iniciador de procesos de servidor DCOM
dcsvc	Servicio de configuración (DC) declarado
defragsvc	Optimizar unidades
DeviceAssociationService	Servicio de asociación de dispositivos
DeviceInstall	Servicio de instalación de dispositivos
DevQueryBroker	Agente de detección en segundo plano de DevQuery
Dhcp	Cliente DHCP
diagsvc	Diagnostic Execution Service
DiagTrack	Experiencia del usuario y telemetría asociadas
DiscordSystemHelper	Discord System Helper
DispBrokerDesktopSvc	Servicio de directivas de pantallas
DisplayEnhancementService	Servicio de mejora de visualización

Figura 11

Inventario parcial de servicios del sistema operativo.

```
Nombre de imagen              PID Servicios
========================= ======== ============================================
System Idle Process             0 N/D
System                          4 N/D
Secure System                 188 N/D
Registry                      232 N/D
smss.exe                      788 N/D
csrss.exe                    1292 N/D
wininit.exe                  1444 N/D
services.exe                 1564 N/D
LsaIso.exe                   1608 N/D
lsass.exe                    1616 KeyIso, SamSs, VaultSvc
svchost.exe                  1748 BrokerInfrastructure, DcomLaunch, PlugPlay,
                                  Power, SystemEventsBroker
fontdrvhost.exe              1788 N/D
svchost.exe                  1876 RpcEptMapper, RpcSs
svchost.exe                  1924 LSM
svchost.exe                  1180 HvHost
svchost.exe                  1676 Schedule
svchost.exe                  1684 NcbService
svchost.exe                  2056 TimeBrokerSvc
svchost.exe                  2064 ProfSvc
svchost.exe                  2192 UserManager
svchost.exe                  2204 hidserv
svchost.exe                  2264 nsi
svchost.exe                  2392 netprofm
svchost.exe                  2448 CoreMessagingRegistrar
svchost.exe                  2644 Dnscache
svchost.exe                  2788 Dhcp
svchost.exe                  2876 hns
svchost.exe                  2884 WinHttpAutoProxySvc
svchost.exe                  3032 nvagent
svchost.exe                  2368 BFE, mpssvc
amdfendrsr.exe               3076 AMD Crash Defender Service
svchost.exe                  3084 EventLog
atiesrxx.exe                 3092 AMD External Events Utility
AsusCertService.exe          3100 AsusCertService
svchost.exe                  3296 SysMain
svchost.exe                  3304 Themes
svchost.exe                  3316 EventSystem
Memory Compression           3404 N/D
svchost.exe                  3444 SENS
svchost.exe                  3484 SharedAccess
svchost.exe                  3492 AudioEndpointBuilder
svchost.exe                  3500 FontCache
svchost.exe                  3592 DispBrokerDesktopSvc
svchost.exe                  3604 Audiosrv
svchost.exe                  3664 TextInputManagementService
svchost.exe                  3864 StateRepository
svchost.exe                  3992 DusmSvc
svchost.exe                  4000 Wcmsvc
svchost.exe                  4052 webthreatdefsvc
audiodg.exe                  4136 N/D
```

Figura 12

Asociación de nombres de imagen, PIDs y servicios en ejecución.

```
PS C:\WINDOWS\System32> Test-NetConnection -ComputerName localhost -Port 80
ADVERTENCIA: TCP connect to (::1 : 80) failed
ADVERTENCIA: TCP connect to (127.0.0.1 : 80) failed


ComputerName            : localhost
RemoteAddress           : ::1
RemotePort              : 80
InterfaceAlias          : Loopback Pseudo-Interface 1
SourceAddress           : ::1
PingSucceeded           : True
PingReplyDetails (RTT) : 0 ms
TcpTestSucceeded        : False



PS C:\WINDOWS\System32> Test-NetConnection -ComputerName localhost -Port 57539
ADVERTENCIA: TCP connect to (::1 : 57539) failed


ComputerName     : localhost
RemoteAddress    : 127.0.0.1
RemotePort       : 57539
InterfaceAlias   : Loopback Pseudo-Interface 1
SourceAddress    : 127.0.0.1
TcpTestSucceeded : True



PS C:\WINDOWS\System32> Test-NetConnection -ComputerName localhost -Port 9013
ADVERTENCIA: TCP connect to (::1 : 9013) failed


ComputerName     : localhost
RemoteAddress    : 127.0.0.1
RemotePort       : 9013
InterfaceAlias   : Loopback Pseudo-Interface 1
SourceAddress    : 127.0.0.1
TcpTestSucceeded : True



PS C:\WINDOWS\System32> Test-NetConnection -ComputerName localhost -Port 139
ADVERTENCIA: TCP connect to (::1 : 139) failed
ADVERTENCIA: TCP connect to (127.0.0.1 : 139) failed


ComputerName            : localhost
RemoteAddress           : ::1
RemotePort              : 139
InterfaceAlias          : Loopback Pseudo-Interface 1
SourceAddress           : ::1
PingSucceeded           : True
PingReplyDetails (RTT) : 0 ms
```

Figura 13

Comprobación autorizada de alcance limitado para la conectividad de puertos.

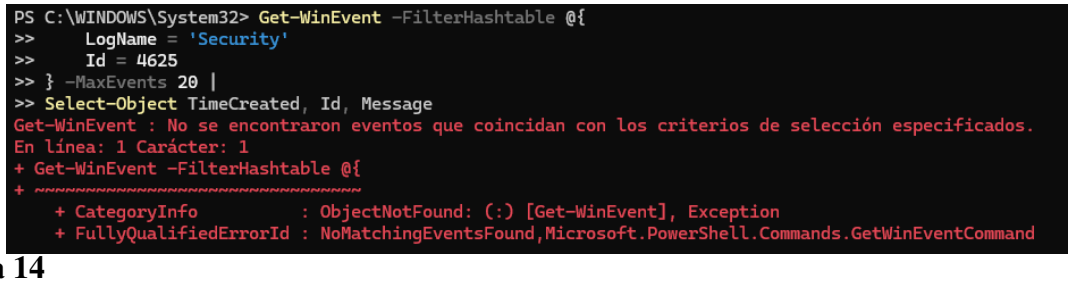


Figura 14

Consulta de registros de eventos de autenticación y seguridad.

```
PS C:\WINDOWS\System32> Get-CimInstance Win32_Service |
>> Select-Object Name, StartName, State |
>> Format-Table -AutoSize

Name                                    StartName                   State
----                                    ---------                   -----
ADPSvc                                  NT AUTHORITY\LocalService   Stopped
ALG                                     NT AUTHORITY\LocalService   Stopped
AMD Crash Defender Service              LocalSystem                 Running
AMD External Events Utility             LocalSystem                 Running
AmdAppCompatSvc                         LocalSystem                 Stopped
AmdPpkgSvc                              LocalSystem                 Running
AppIDSvc                                NT Authority\LocalService   Stopped
Appinfo                                 LocalSystem                 Running
AppReadiness                            LocalSystem                 Stopped
AppXSvc                                 LocalSystem                 Running
ApxSvc                                  NT AUTHORITY\LocalService   Stopped
ArmouryCrateService                     LocalSystem                 Running
asus                                    LocalSystem                 Stopped
AsusCertService                         LocalSystem                 Running
AsusFanControlService                   LocalSystem                 Running
asusm                                   LocalSystem                 Stopped
AsusROGLSLService                       LocalSystem                 Stopped
AsusUpdateCheck                         LocalSystem                 Running
AudioEndpointBuilder                    LocalSystem                 Running
Audiosrv                                NT AUTHORITY\LocalService   Running
Aura Wallpaper Service                  LocalSystem                 Running
autotimesvc                             NT AUTHORITY\LocalService   Stopped
AxInstSV                                LocalSystem                 Stopped
BDESVC                                  localSystem                 Stopped
BFE                                     NT AUTHORITY\LocalService   Running
BITS                                    LocalSystem                 Stopped
BrokerInfrastructure                    LocalSystem                 Running
BTAGService                             NT AUTHORITY\LocalService   Stopped
BthAvctpSvc                             NT AUTHORITY\LocalService   Stopped
bthserv                                 NT AUTHORITY\LocalService   Running
camsvc                                  LocalSystem                 Running
CDPSvc                                  NT AUTHORITY\LocalService   Running
CertPropSvc                             LocalSystem                 Stopped
ClickToRunSvc                           LocalSystem                 Running
ClipSVC                                 LocalSystem                 Stopped
com.docker.service                      LocalSystem                 Stopped
COMSysApp                               LocalSystem                 Stopped
CoreMessagingRegistrar                  NT AUTHORITY\LocalService   Running
CryptSvc                                NT Authority\NetworkService Running
DcomLaunch                              LocalSystem                 Running
dcsvc                                   LocalSystem                 Stopped
defragsvc                               localSystem                 Stopped
DeviceAssociationService                LocalSystem                 Running
DeviceInstall                           LocalSystem                 Stopped
DevQueryBroker                          LocalSystem                 Stopped
Dhcp                                    NT Authority\LocalService   Running
diagsvc                                 LocalSystem                 Stopped
```

Figura 15

Revisión de cuentas de inicio y privilegios asociados a los servicios del sistema.

Resultados obtenidos: A partir del análisis de las evidencias gráficas, se obtuvieron los siguientes resultados concretos:

- **Puertos en estado LISTEN:** Se identificaron múltiples puertos activos en escucha (Figura 10), destacando conexiones ligadas a interfaces `127.0.0.1`, `::1`, `0.0.0.0`, `::`, así como interfaces específicas como `192.168.101.16` y `172.31.144.1` en el puerto `139` (asociado al proceso PID `4`).

- **Servicios y procesos asociados:** La correlación de PIDs (Figura 12) permitió identificar servicios del núcleo y componentes de virtualización o soporte (ej. `svchost.exe`, `lsass.exe`), sin evidencias visuales directas de la ejecución de servidores web HTTP o FTP tradicionales en las trazas expuestas.

- **Comprobación de exposición:** Las pruebas mediante `Test-NetConnection` (Figura 13) mostraron fallos de conexión (`TcpTestSucceeded : False`) al intentar alcanzar puertos como el `80` y el `139` en bucle local (`::1`), mientras que otros puertos internos respondieron de forma local.

- **Eventos de autenticación:** La consulta al registro de eventos de seguridad buscando el Id `4625` (inicios de sesión fallidos) arrojó el mensaje de error *"No se encontraron eventos que coincidan con los criterios de selección especificados"* (Figura 14), lo que indica ausencia de registros bajo ese filtro en el momento de la captura.

- **Cuentas de ejecución y privilegios:** La inspección de instancias de servicio (Figura 15) evidenció que una gran proporción de los servicios del sistema operan bajo cuentas altamente privilegiadas como `LocalSystem`, mientras que otros utilizan cuentas de servicio restringidas como `NT AUTHORITY\LocalService` o `NT AUTHORITY\NetworkService`.

Tabla 9

Inventario de servicios expuestos

Puerto	Servicio	Versión	¿Necesario?	Propietario	Riesgo / observación
139	NetBIOS Session	v4.0 / Heredado	**No** (Heredado)	Sistema (4)	Expuesto en interfaces `192.168.101.16` y `172.31.144.1`; riesgo potencial de enumeración SMB/NetBIOS si hay acceso externo no filtrado.
445	SMB (Direct Hosting)	SMBv2 / SMBv3	**Solo Local**	Sistema (4)	Escucha en interfaces comodín (`::` y `0.0.0.0`); requiere validación de reglas de firewall perimetral y limitar el acceso externo.
3306 / 33060	MySQL / X Protocol	v8.0.x (Community)	**Sí** (Condicional)	No determinado	Escucha configurada en interfaces de bucle invertido y local (`::`), limitando el riesgo de acceso externo directo.

Inventario de servicios expuestos:

Análisis de seguridad e indicadores: Se evaluaron los indicadores de la guía frente a las evidencias:

1. **Servicios expuestos sin necesidad:** No determinado de forma concluyente; aunque existen puertos en escucha, la mayoría se restura a interfaces de loopback o requiere validación de firewall. El puerto `139` muestra enlace en interfaces de red específicas.

2. **Software sin soporte o desactualizado:** No fue posible determinar versiones específicas de software a partir de las capturas disponibles.

3. **Intentos de autenticación fallidos:** No se identificó evidencia de eventos fallidos debido a que la consulta de seguridad no retornó registros coincidentes (Figura 14).

4. **Uso de protocolos en texto claro:** No determinado con las capturas analizadas, ya que no se interceptó tráfico de aplicación HTTP/FTP.

5. **Configuraciones por defecto:** No determinado; se observa predominio de servicios nativos del sistema operativo bajo cuentas predeterminadas.

Tabla 10
Matriz de riesgo y criticidad del Caso 3

Identificador	Elemento	Hallazgo	Impacto	Probab.	Riesgo	Justificación
C3-H01	Puertos SMB / NetBIOS (139, 445)	Escucha en interfaces de red secundarias e IP comodín.	Medio	Bajo	Medio	La exposición de servicios SMB en redes corporativas puede facilitar ataques lateralización si no hay filtrado perimetral estricto.
C3-H02	Cuentas de Servicios	Uso extendido de la cuenta `LocalSystem` en múltiples servicios.	Alto	Bajo	Medio	Incrementa el radio de impacto en caso de que un servicio sufra un compromiso de ejecución de código.

Matriz de riesgo y criticidad:

Tabla 11
Plan de remediación y defensa propuesto

Hallazgo / Riesgo	Acción recomendada	Prioridad	Responsable	Verificación
Exposición de puertos SMB (139/445)	Restringir el tráfico SMB mediante reglas de firewall local y perimetral, bloqueando el acceso desde redes no confiables.	Media	Adm. de Infraestructura	Escaneo de puertos local/remoto (`nmap`).
Privilegios excesivos en servicios	Auditar y migrar servicios ejecutados bajo `LocalSystem` hacia cuentas de servicio con privilegios mínimos (`NetworkService` o cuentas dedicadas).	Media	Adm. de Sistemas	Revisión de configuraciones de servicios (`Get-CimInstance`).

Plan de remediación y defensa:

Preguntas de análisis:

1. **¿Cómo se prioriza un puerto abierto?**

   La priorización no depende únicamente del número del puerto, sino de una evaluación integral que incluye: el servicio de red subyacente asociado, su necesidad operativa real para el negocio, la accesibilidad de la interfaz de red donde escucha (loopback frente a interfaz pública), la versión del software, la existencia de vulnerabilidades conocidas publicadas, los mecanismos de autenticación y cifrado soportados, y el impacto potencial que tendría una explotación exitosa sobre la confidencialidad, integridad y disponibilidad del sistema.

2. **¿Qué diferencia hay entre exposición, vulnerabilidad y explotación?**

Exposición describe la condición en la cual un servicio o puerto se encuentra accesible o disponible a través de una interfaz de red o sistema operativo. *Vulnerabilidad* representa una debilidad o fallo técnico específico en la implementación o configuración del servicio que puede ser aprovechado. *Explotación* es la fase activa donde un atacante utiliza dicha vulnerabilidad para quebrantar los controles de seguridad y lograr un acceso o efecto no autorizado. Por ejemplo, un servidor con el puerto HTTP abierto está *expuesto*; si el software web contiene un desbordamiento de búfer sin parches, posee una *vulnerabilidad*; y si un script malicioso utiliza ese fallo para inyectar código, se ha concretado una *explotación*.

Conclusiones:

- Se logró realizar el inventario de puertos en estado de escucha y de los servicios del sistema operativo disponibles en el entorno evaluado, identificando enlaces en interfaces de bucle local, comodín y algunas direcciones de red específicas como el puerto `139`.
- Se comprobó que el alcance de la exposición de ciertos puertos está limitado a nivel de interfaces locales, aunque se detectó la necesidad de mantener un control estricto mediante cortafuegos para evitar accesos no autorizados.
- La revisión de los registros de autenticación y eventos no arrojó trazas de eventos de error de inicio de sesión bajo los filtros consultados, limitando la detección de anomalías de acceso activo en las evidencias analizadas.
- Se evidenció que gran parte de los servicios del sistema operan bajo la cuenta `LocalSystem`, lo que destaca una oportunidad de mejora en la aplicación del principio de mínimo privilegio.
- Las evidencias disponibles presentaron limitaciones para determinar versiones de software específicas o el uso de protocolos cifrados, por lo que se recomienda complementar la evaluación con escaneos de vulnerabilidades y auditorías de configuración avanzadas.

Tabla 12
Ficha de registro del hallazgo. Caso 3

Campo	Registro
Identificador	C3-H01
Fecha y hora	No especificada en las evidencias de consola proporcionadas.
Origen/destino	Local / Interfaces de red locales (`192.168.101.16`, `172.31.144.1`) y bucle invertido (`127.0.0.1`, `::1`).
Observación	Presencia de puertos en estado `LISTEN` asociados a servicios de red y del sistema operativo, incluyendo puertos NetBIOS (139) y SMB (445).
Hipótesis	Si los puertos de administración o servicios heredados están accesibles desde interfaces externas sin control de firewall, se incrementa la superficie de ataque ante intrusiones.
Validación	Respaldado por el inventario de puertos en escucha obtenido mediante comandos del sistema (Figura 10).
Severidad	Media.
Acción	Aplicar filtrado de puertos perimetral, restringir servicios innecesarios y verificar la directiva de minimización de privilegios.
Integridad	Imágenes fuente: `01_puertos_escucha.png`, `02_servicios_sistema.png`, `03_identificacion_servicios.png`, `04_comprobacion_exposicion.png`, `05_eventos_autenticacion.png`, `06_cuentas_privilegios.png`. (Hashes SHA-256 no suministrados).

Ficha de registro del hallazgo. Caso 3.

6.4. Caso 4. Detección de anomalías con IA/ML en tráfico TCP/IP

Situación

El equipo debe proponer una defensa inteligente que identifique desviaciones frente al tráfico normal.

Procedimiento.

- Crear un conjunto de datos con PCAP didácticos o tráfico benigno de laboratorio y características agregadas: conexiones por minuto, bytes por flujo, duración, flags TCP y proporción petición/respuesta.
- Separar los datos de entrenamiento y evaluación por tiempo o por sesión para evitar fuga de

información.

- Comparar una línea base estadística con un detector de anomalías; documentar precisión, falsos positivos y límites. Se puede usar scikit-learn como referencia (Scikit-learn developers, 2026).
- Anonimizar los ejemplos y proteger los datos de entrenamiento.

Indicadores que deben buscarse. Desviación sostenida respecto a la línea base; puntuación de anomalía alta que debe investigarse junto con evidencia de red y registros.

Mitigación y defensa. Mantener revisión humana; monitorizar la deriva del modelo; no usar la salida de un prototipo como única razón para bloquear; proteger los datos de entrenamiento.

Evidencias que se entregan. Notebook o script reproducible, definición de atributos, métricas, matriz de confusión si hay etiquetas y ejemplos anonimizados.

Preguntas de análisis.

1. ¿Cómo afectan el desbalance de clases y los cambios legítimos de carga?
2. ¿Qué métrica es más útil para este caso?

Tabla 13
Características agregadas para el detector de anomalías

Característica	Definición operativa	Unidad	Ventana
Conexiones por minuto		conexiones/min	
Bytes por flujo		bytes	
Duración del flujo		segundos	
Flags TCP		conteo	
Proporción petición/respuesta		razón	

Tabla 14

Ficha de registro del hallazgo. Caso 4

Campo	Registro
Identificador	
Fecha y hora	
Origen/destino	
Observación	
Hipótesis	
Validación	
Severidad	
Acción	
Integridad	

6.5. Caso 5. TCP: resets inesperados e indicios de inyección o desincronización

Situación

Las aplicaciones reportan sesiones TCP que terminan abruptamente o se reinician de forma repetida.

Objetivo:

Identificar y analizar paquetes TCP con la bandera RST en una captura de tráfico de laboratorio mediante el filtrado y correlación de sesiones, marcas de tiempo, puertos e IPs. Con este análisis se busca discernir si los reinicios de conexión corresponden a un comportamiento legítimo o a patrones anómalos, como inyección de paquetes o desincronización, correlacionando los eventos con registros del sistema para evaluar su contexto, establecer causas y proponer medidas de mitigación que preserven la integridad y disponibilidad de la red.

Fundamento Teórico:

El protocolo TCP garantiza conexiones confiables mediante el three-way handshake, empleando la bandera RST (Reset) para interrumpir abruptamente una sesión cuando ocurren fallos legítimos como puertos cerrados o caídas de aplicaciones; sin embargo, su presencia anómala también puede alertar sobre inyecciones de tráfico o desincronizaciones de red. Debido a esto, la detección aislada de un paquete RST no evidencia un ataque por sí misma, requiriendo un análisis forense riguroso en Wireshark (tcp.flags.reset == 1) que examine flujos y secuencias, y que sea correlacionado con logs de sistemas operativos e IDS (como Zeek o Suricata). Finalmente, mitigar la manipulación de estas conexiones exige una estrategia de defensa en profundidad basada en el endurecimiento de plataformas, segmentación de red, uso de IDS/IPS y el cifrado de datos mediante protocolos seguros como TLS.

Procedimiento: Para llevar a cabo el análisis del comportamiento TCP y la búsqueda de paquetes de reinicio, se ejecutó la siguiente metodología:

1. **Verificación de integridad de la captura:** Se calculó el resumen criptográfico SHA-256 de la PCAP de laboratorio para garantizar la autenticidad y no alteración de la evidencia digital.

2. **Inspección y filtrado de paquetes RST:** Se cargó el archivo en Wireshark y se aplicó el filtro de visualización `tcp.flags.reset == 1` para aislar cualquier segmento con la bandera de reinicio activa.

3. **Análisis de flujos y sesiones TCP:** Se examinaron los flujos de comunicación mediante la opción *Follow TCP Stream* para verificar los números de secuencia, las banderas de establecimiento y el mecanismo de cierre de las conexiones.

4. **Evaluación temporal del tráfico:** Se empleó la herramienta gráfica *I/O Graphs* de Wireshark para analizar la distribución temporal de los paquetes a lo largo de la captura y detectar posibles ráfagas o anomalías.

Resultados obtenidos: A partir de la inspección de las evidencias proporcionadas por las capturas de Wireshark y la ejecución de herramientas del sistema, se obtuvieron los siguientes resultados cuantitativos y cualitativos:

- **Integridad del archivo PCAP:** Mediante la ejecución del comando de verificación en PowerShell (Figura 16), se obtuvo el hash SHA-256 correspondiente al archivo original:

`5295B16EA117FA8BB1A65418FCA81E709BEA58D3A830BC3BB5C4A2ED0466EA9C`

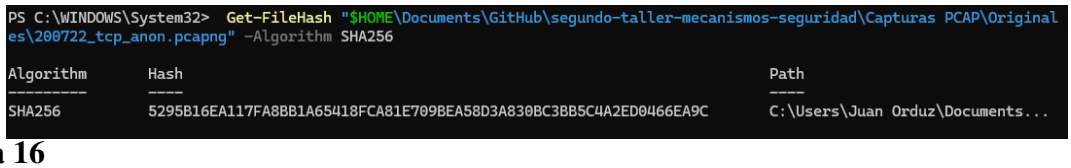


Figura 16
Cálculo de integridad del archivo PCAP mediante SHA-256[cite: 1].

- **Análisis de paquetes RST:** Al aplicar el filtro `tcp.flags.reset == 1` en Wireshark (Figura 17), se constató que **no existe ningún paquete con la bandera RST activa** (0 coincidencias en toda la captura). Las conexiones analizadas siguen un ciclo de vida estándar basado en el establecimiento clásico de tres vías (`SYN`, `SYN/ACK`, `ACK`) y un cierre ordenado mediante banderas `FIN/ACK`.

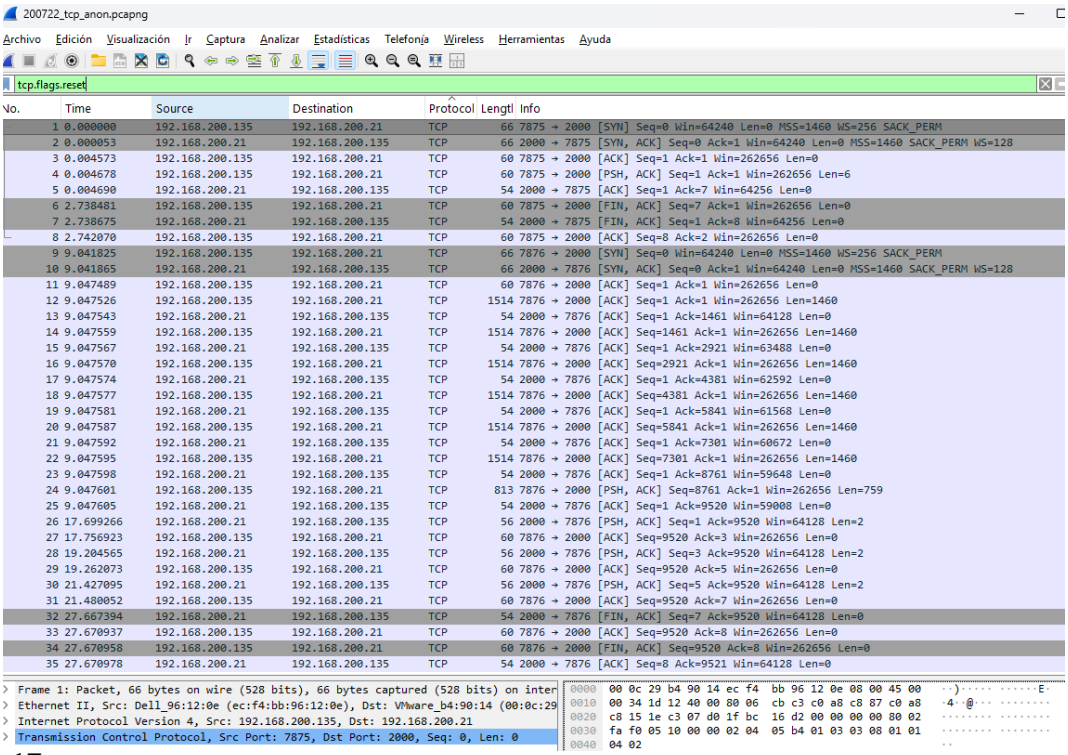


Figura 17

Inspección de las sesiones TCP en la captura de tráfico[cite: 2].

- **Inspección de flujos y distribución temporal:** Al examinar la estructura del encabezado TCP en la sesión de referencia (Figura 18) y al graficar la distribución del tráfico a lo largo del tiempo (Figura 19), se ratifica la estabilidad de la red sin fluctuaciones ni patrones anómalos de reinicio.

Análisis de seguridad e indicadores: A partir de los resultados obtenidos, se evaluaron los indicadores clave de anomalía en sesiones TCP:

- **RST fuera de contexto:** No se detectaron segmentos de reinicio, por lo que no existen evidencias de desconexiones forzadas por esta vía.
- **Frecuencia inusual:** La tasa de paquetes RST es nula (0 pkt/s), descartando ráfagas o ataques de denegación por reseteo de conexiones.
- **Sesiones truncadas:** Las comunicaciones finalizan de manera ordenada mediante el intercambio de paquetes `FIN` y `ACK`, confirmando la integridad del ciclo de cierre.

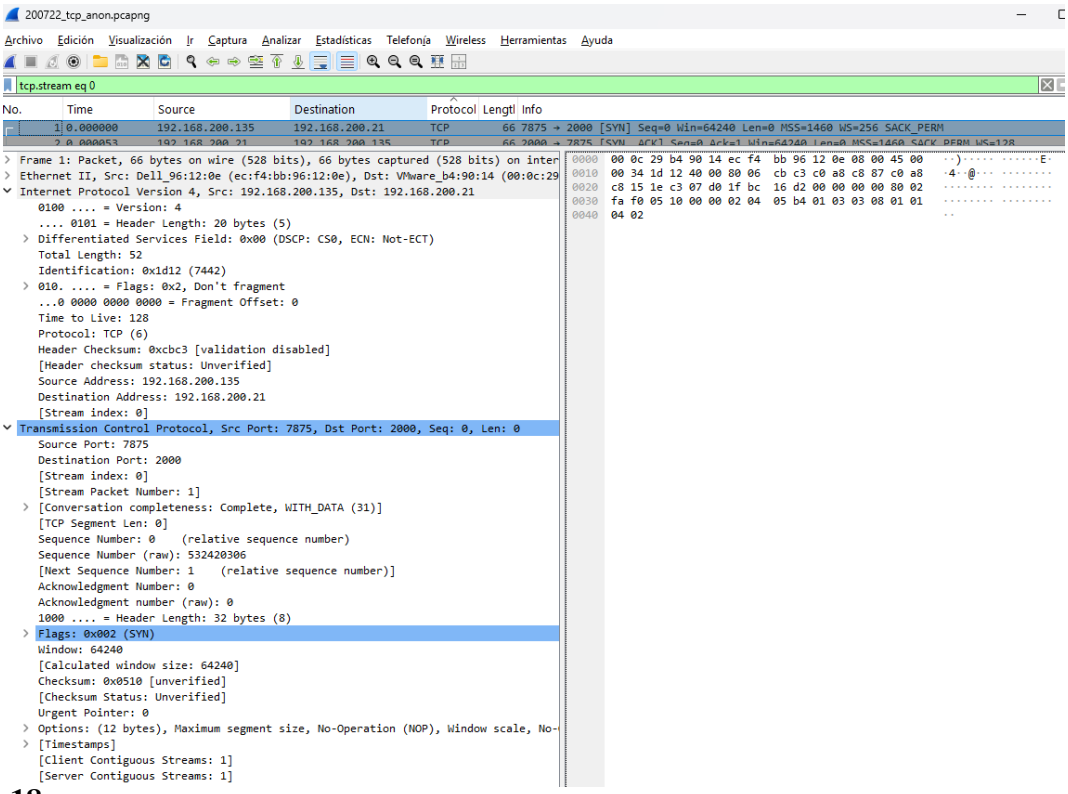


Figura 18

Detalle de la estructura del segmento TCP en la sesión analizada[cite: 3].

- **Inconsistencia de secuencia:** Los números de secuencia y reconocimiento se mantienen coherentes a lo largo de las sesiones evaluadas.

Mitigación y defensa: Para preservar la robustez de las comunicaciones frente a potenciales escenarios de inyección o reseteo malicioso, se proponen las siguientes medidas defensivas:

- **Cifrado de extremo a extremo:** Implementar TLS con validación estricta de certificados para impedir la manipulación del contenido de las sesiones.
- **Segmentación de red:** Aislar los servicios críticos mediante políticas de control de acceso y *firewalls*.
- **Monitoreo con IDS/IPS:** Configurar reglas de detección orientadas a identificar anomalías en los encabezados TCP y ráfagas anormales de paquetes de control.

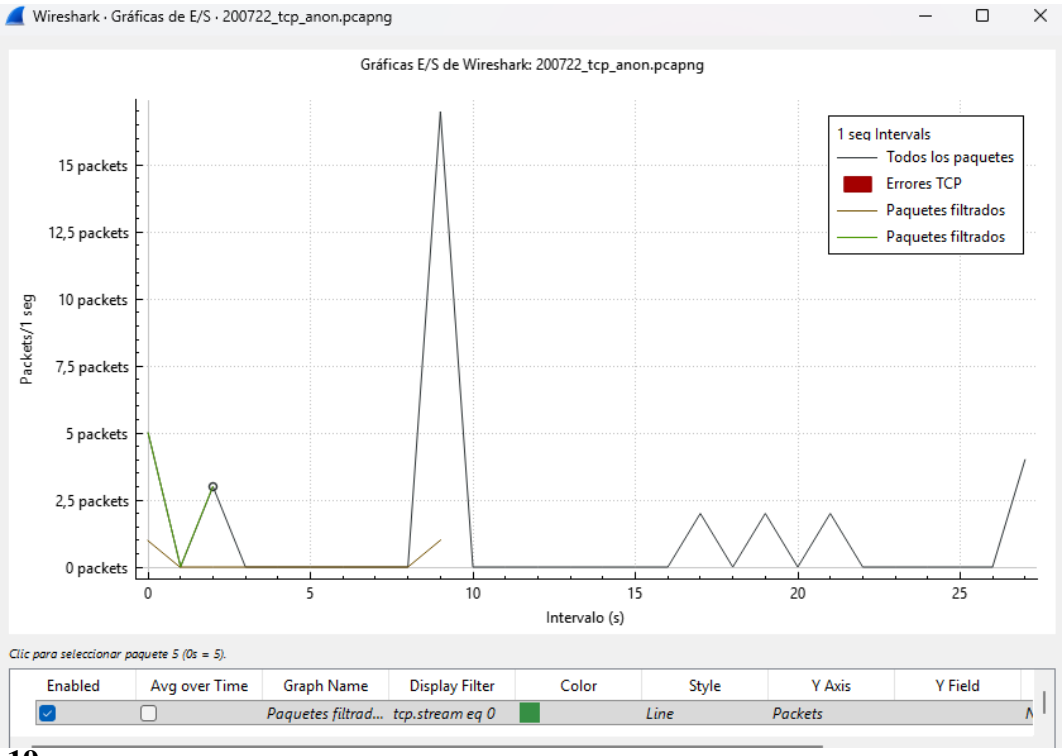


Figura 19

Gráfica de E/S de la distribución del flujo TCP a lo largo del tiempo[cite: 4].

- **Correlación de registros:** Integrar la auditoría de eventos del sistema operativo con las trazas de red para verificar la legitimidad de los cierres de sesión.

Conclusiones: El análisis detallado de la captura de tráfico `200722_tcp_anon.pcapng` permitió determinar que los flujos de comunicación evaluados operan bajo parámetros completamente normales. La ausencia total de paquetes con la bandera `RST` activa y la presencia de cierres de sesión estructurados mediante `FIN/ACK` descartan la existencia de indicios de inyección o desincronización maliciosa en este escenario de laboratorio.

Preguntas de análisis.

1. **¿Qué causas benignas generan RST?**

   - Intentos de conexión (`SYN`) dirigidos a puertos donde no hay servicios escuchando.
   - Cierres abruptos o terminaciones de procesos en las aplicaciones cliente o servidor.
   - Reinicios o detenciones de servicios de red a nivel del sistema operativo.

Tabla 15
Resumen de flujos TCP analizados en la captura.

Flujo	IP Origen	Puerto A	IP Destino	Puerto B	Paquetes RST	Interpretación
F01	192.168.200.135	7875	192.168.200.21	2000	0	Tráfico legítimo (FIN/ACK)
F02	192.168.200.135	7876	192.168.200.21	2000	0	Tráfico legítimo (FIN/ACK)

- Políticas de seguridad implementadas en *firewalls* o dispositivos intermedios que rechazan de forma activa un flujo.
- Pérdida de sincronismo o estado de la conexión ante reinicios legítimos de los equipos extremos.

2. **¿Qué evidencia adicional haría más sólida la hipótesis de manipulación?**

- Identificación de paquetes `RST` con números de secuencia fuera de ventana o inconsistentes con el estado real de la sesión.
- Capturas de tráfico simultáneas en ambos extremos de la comunicación (origen y destino) para constatar si el paquete de reinicio fue inyectado en el medio por un atacante (MITM).
- Ausencia de registros de error o reinicio en los sistemas operativos que justifiquen la emisión del *Reset*.
- Alertas generadas por un sistema de detección de intrusos (NIDS/NSM) que reporten anomalías en los flujos TCP.

Ficha de registro del hallazgo. Caso 5

6.6. Caso 6. UDP: reflexión/amplificación DNS, NTP o SSDP

Situación

El servidor o gateway registra un volumen inusual de respuestas UDP, posiblemente desproporcionado respecto de las solicitudes.

Procedimiento.

Tabla 16
Ficha técnica de registro del hallazgo para el Caso 5.

Campo	Registro
Identificador	H-CU5-01
Fecha y hora	2026-07-22 (Captura de laboratorio anonimizada)
Origen/destino	`192.168.200.135` (Puerto 7875/7876) ↔ `192.168.200.21` (Puerto 2000)
Observación	Ausencia total de paquetes `RST`; sesiones con cierre ordenado `FIN/ACK`.
Hipótesis	Tráfico de red legítimo sin indicios de inyección, manipulación ni reseteo anómalo.
Validación	Filtrado mediante `tcp.flags.reset == 1` (0 resultados) y revisión de flujos TCP.
Severidad	Baja / Informativa
Acción	Documentar el comportamiento normal y mantener monitoreo preventivo de red.
Integridad	SHA-256: `5295B16EA117FA8BB1A65418FC A81E709BEA58D3A830BC3BB5C4A2ED 0466EA9C`

- Examinar el volumen por protocolo, origen, destino y ventana temporal; distinguir el tráfico esperado de las respuestas no solicitadas.
- Revisar la configuración de los servicios propios y confirmar que no actúan como reflectores abiertos.
- No generar tráfico de amplificación: usar PCAP de entrenamiento o contadores agregados simulados.

Indicadores que deben buscarse. Gran volumen de respuestas, asimetría entre peticiones y respuestas, puertos inesperados y destinos no relacionados con las solicitudes observadas.

Mitigación y defensa. Deshabilitar servicios innecesarios; restringir las consultas recursivas DNS; aplicar limitación de tasa y filtrado anti-spoofing en la infraestructura administrada.

Evidencias que se entregan. Gráficas de paquetes y bytes por segundo, inventario de servicios y controles recomendados.

Preguntas de análisis.

1. ¿Cómo se diferencia una ráfaga legítima de un patrón de reflexión?
2. ¿Qué controles corresponden al servidor y cuáles al proveedor de red?

Tabla 17
Ficha de registro del hallazgo. Caso 6

Campo	**Registro**
Identificador	
Fecha y hora	
Origen/destino	
Observación	
Hipótesis	
Validación	
Severidad	
Acción	
Integridad	

6.7. Caso 7. ICMP: escaneo, payloads atípicos y posible túnel

Situación

En una red de laboratorio se observa tráfico ICMP con mayor frecuencia de la habitual y con tamaños de carga que no corresponden a un diagnóstico común. **Objetivo:**

Caracterizar el uso de ICMP en tres escenarios controlados—una línea base de diagnóstico, un barrido de reconocimiento y un túnel simulado—, comparar el comportamiento observado frente a la línea base y proponer indicadores y reglas de detección que permitan distinguir el uso legítimo del abusivo.

Fundamento teórico:

ICMP (*Internet Control Message Protocol*) se define en el RFC 792 (Postel, 1981). Es un protocolo de mensajes de control que viaja directamente sobre IP y cubre dos grandes funciones:

- **Notificación de errores:** destino inalcanzable (tipo 3), tiempo excedido (tipo 11) y redirección (tipo 5), entre otros.
- **Diagnóstico y control:** petición y respuesta de eco (tipos 8 y 0), y descubrimiento de MTU de ruta, que es indispensable para el funcionamiento correcto de la fragmentación.

El campo `data` de un mensaje de eco puede transportar carga arbitraria; por eso ICMP puede usarse como canal encubierto cuando el firewall permite su tránsito sin inspección de contenido. El reto defender es distinguir el eco de diagnóstico de un canal de datos sin bloquear las funciones que la red necesita.

Procedimiento. El laboratorio se desplegó sobre una red Docker puente aislada (`172.28.50.0/24`, opción `internal: true`, sin salida a Internet), con los roles de la Figura 20: analista en `172.28.50.10` y víctima en `172.28.50.20`. Todas las capturas se realizaron con `tcpdump` dentro del contenedor del analista y se analizaron con `tshark` y `Suricata 7.0.7`. El procedimiento fue el siguiente:

1. **Verificación de integridad:** antes de abrir cualquier captura se calculó su huella SHA-256 y se conservó una copia original sin modificar (Figura 21).

2. **Línea base de diagnóstico:** se ejecutó `ping` contra la víctima y se capturó `CU7_01_baseline_icmp.pcap` (4 peticiones de eco y 4 respuestas).

3. **Barrido ICMP:** se enviaron peticiones de eco a 40 direcciones consecutivas del segmento (`172.28.50.1` a `172.28.50.40`) y se capturó `CU7_02_icmp_sweep.pcap`.

4. **Payload atípico / túnel simulado:** se enviaron 15 peticiones de eco con carga de 900 bytes de texto codificado en Base64 al mismo destino y se capturó `CU7_03_icmp_tunnel.pcap`. El tráfico es sintético y no transporta información sensible.

5. **Análisis de metadatos:** con `tshark` se agruparon los paquetes por origen, destino, tipo, código, longitud y tiempo relativo, y se calculó la entropía y la proporción de caracteres imprimibles de la carga (Figura 25).

6. **Validación con IDS:** se reprocesaron las tres capturas con Suricata aplicando el archivo `laboratorio/suricata/local.rules` y se revisó la salida `fast.log` (Figura 26).

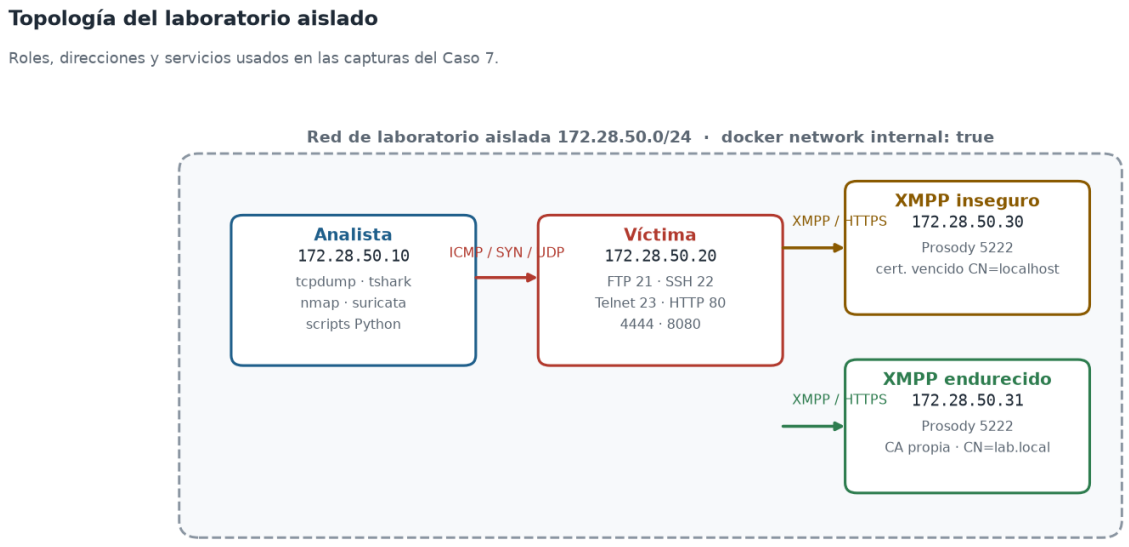


Figura 20
Topología del laboratorio aislado empleada en el Caso 7.

Integridad de las capturas del Caso 7

Huellas SHA-256 calculadas antes del análisis (sha256sum sobre las copias originales).

Archivo	Tamaño	SHA-256
CU7_01_baseline_icmp.pcap	936 B	c3af28d1df0ac1a248bd6361f8a7898e e241a1cf5fb4d827c87643e5268caee5
CU7_02_icmp_sweep.pcap	4.896 B	95c75cdfd7b4be61f00493ba50ade17c 5b03c6ec9dbf3051a7b289f829273c2d
CU7_03_icmp_tunnel.pcap	28.764 B	7d32a148c00de6aa0a98d03aab3954d6 e44e1d805a1370ade2250c813c111c8c

Figura 21

Verificación de integridad de las capturas del Caso 7 mediante SHA-256.

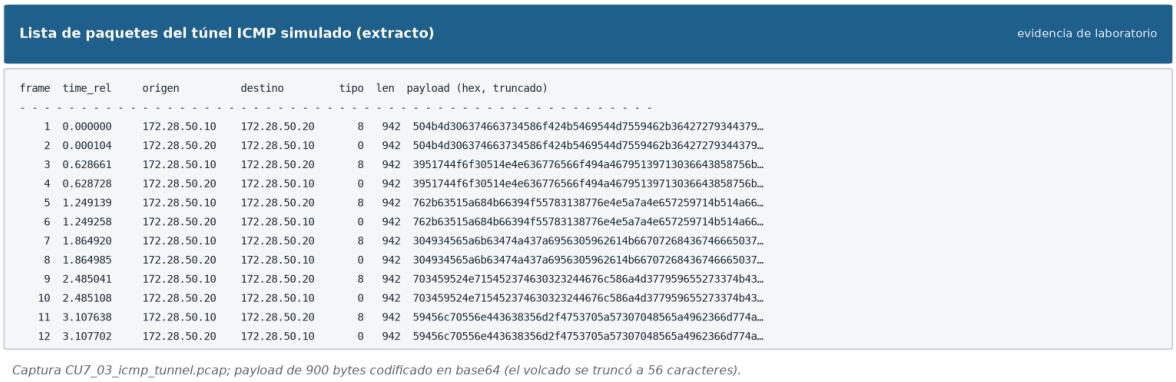
Lista de paquetes del barrido ICMP (extracto) evidencia de laboratorio

frame	time_rel	origen	destino	tipo	len	información
1	0.000000	172.28.50.10	172.28.50.1	8	42	Echo request id=0x0000, seq=0/0, ttl=64
2	0.001184	172.28.50.10	172.28.50.1	8	42	Echo request id=0x0000, seq=0/0, ttl=64
3	0.001293	172.28.50.1	172.28.50.10	0	42	Echo reply id=0x0000, seq=0/0, ttl=64 (re
4	0.024736	172.28.50.10	172.28.50.2	8	42	Echo request id=0x0000, seq=0/0, ttl=64
5	0.024791	172.28.50.10	172.28.50.2	8	42	Echo request id=0x0000, seq=0/0, ttl=64
6	0.064564	172.28.50.10	172.28.50.3	8	42	Echo request id=0x0000, seq=0/0, ttl=64
7	0.064613	172.28.50.10	172.28.50.3	8	42	Echo request id=0x0000, seq=0/0, ttl=64
8	0.104283	172.28.50.10	172.28.50.4	8	42	Echo request id=0x0000, seq=0/0, ttl=64
9	0.104333	172.28.50.10	172.28.50.4	8	42	Echo request id=0x0000, seq=0/0, ttl=64
10	0.136357	172.28.50.10	172.28.50.5	8	42	Echo request id=0x0000, seq=0/0, ttl=64
11	0.136397	172.28.50.10	172.28.50.5	8	42	Echo request id=0x0000, seq=0/0, ttl=64
12	0.167864	172.28.50.10	172.28.50.6	8	42	Echo request id=0x0000, seq=0/0, ttl=64
13	0.167923	172.28.50.10	172.28.50.6	8	42	Echo request id=0x0000, seq=0/0, ttl=64
14	0.199707	172.28.50.10	172.28.50.7	8	42	Echo request id=0x0000, seq=0/0, ttl=64
15	0.199765	172.28.50.10	172.28.50.7	8	42	Echo request id=0x0000, seq=0/0, ttl=64
16	0.232286	172.28.50.10	172.28.50.8	8	42	Echo request id=0x0000, seq=0/0, ttl=64
17	0.232333	172.28.50.10	172.28.50.8	8	42	Echo request id=0x0000, seq=0/0, ttl=64
18	0.256341	172.28.50.10	172.28.50.9	8	42	Echo request id=0x0000, seq=0/0, ttl=64
19	0.256388	172.28.50.10	172.28.50.9	8	42	Echo request id=0x0000, seq=0/0, ttl=64
20	0.300846	172.28.50.10	172.28.50.10	8	42	Echo request id=0x0000, seq=0/0, ttl=64
21	0.300899	172.28.50.10	172.28.50.10	8	42	Echo request id=0x0000, seq=0/0, ttl=64
22	0.328339	172.28.50.10	172.28.50.11	8	42	Echo request id=0x0000, seq=0/0, ttl=64
23	0.328394	172.28.50.10	172.28.50.11	8	42	Echo request id=0x0000, seq=0/0, ttl=64
24	0.363805	172.28.50.10	172.28.50.12	8	42	Echo request id=0x0000, seq=0/0, ttl=64
25	0.363876	172.28.50.10	172.28.50.12	8	42	Echo request id=0x0000, seq=0/0, ttl=64
26	0.395682	172.28.50.10	172.28.50.13	8	42	Echo request id=0x0000, seq=0/0, ttl=64

Captura CU7_02_icmp_sweep.pcap; se muestran las primeras 26 tramas de 84. Cada destino aparece duplicado por la réplica del puente virtual.

Figura 22

Lista de paquetes del barrido ICMP (extracto de `CU7_02_icmp_sweep.pcap`).



Lista de paquetes del túnel ICMP simulado (extracto) — evidencia de laboratorio

frame	time_rel	origen	destino	tipo	len	payload (hex, truncado)
1	0.000000	172.28.50.10	172.28.50.20	8	942	504b4d3063746637345 86f424b5469544d7559462b36427279344379…
2	0.000104	172.28.50.20	172.28.50.10	0	942	504b4d3063746637345 86f424b5469544d7559462b36427279344379…
3	0.628661	172.28.50.10	172.28.50.20	8	942	3951744f6f30514e4e636776566f494a467951397130366438587 56b…
4	0.628728	172.28.50.20	172.28.50.10	0	942	3951744f6f30514e4e636776566f494a467951397130366438587 56b…
5	1.249139	172.28.50.10	172.28.50.20	8	942	762b63515a684b66394f55783138776e4e5a7a4e657259714b514a66…
6	1.249258	172.28.50.20	172.28.50.10	0	942	762b63515a684b66394f55783138776e4e5a7a4e657259714b514a66…
7	1.864920	172.28.50.10	172.28.50.20	8	942	304934565a6b63474a437a695630596261 4b667072684367466650 37…
8	1.864985	172.28.50.20	172.28.50.10	0	942	304934565a6b63474a437a695630596261 4b667072684367466650 37…
9	2.485041	172.28.50.10	172.28.50.20	8	942	703459524e7154523746303232446 76c586a4d377959655273374b43…
10	2.485108	172.28.50.20	172.28.50.10	0	942	703459524e7154523746303232446 76c586a4d377959655273374b43…
11	3.107638	172.28.50.10	172.28.50.20	8	942	59456c70556e443638356d2f4753705a57307048565a4962366d774a…
12	3.107702	172.28.50.20	172.28.50.10	0	942	59456c70556e443638356d2f4753705a57307048565a4962366d774a…

Captura CU7_03_icmp_tunnel.pcap; payload de 900 bytes codificado en base64 (el volcado se truncó a 56 caracteres).

Figura 23
Lista de paquetes del túnel ICMP simulado (extracto de `CU7_03_icmp_tunnel.pcap`).

Resultados obtenidos. El análisis cuantitativo de las tres capturas se resume en la Tabla 18. Cada cifra proviene del script de análisis `laboratorio/scripts/analyze_cu7.py` sobre los mismos archivos cuya integridad se verificó.

Tabla 18
Distribución de tráfico ICMP por tipo y longitud

Tipo	Código	Longitud	Origen	Destino	Frecuencia / observación
8	0	98	172.28.50.10	172.28.50.20	4 peticiones/0,88 s, carga de 40 bytes (línea base).
0	0	98	172.28.50.20	172.28.50.10	4 respuestas simétricas, latencia media 121 ms.
8	0	42	172.28.50.10	172.28.50.1–40	40 destinos únicos en 0,7 s, carga vacía (barrido).
0	0	42	172.28.50.1–4	172.28.50.10	Solo 4 respuestas; el resto no contesta.
8	0	942	172.28.50.10	172.28.50.20	15 peticiones cada 0,62 s, carga de 900 bytes (túnel).
0	0	942	172.28.50.20	172.28.50.10	15 respuestas que replican la misma carga Base64.

- **Línea base (`CU7_01`):** 8 paquetes, 4 peticiones y 4 respuestas con carga constante de 40 bytes, intervalo medio de 0,88 s y entropía de 5,322 bits/byte. Es el patrón esperado de un `ping` de diagnóstico.
- **Barrido (`CU7_02`):** 84 paquetes capturados; 80 peticiones de eco que corresponden a 40

destinos únicos (cada paquete aparece duplicado por la réplica del puente virtual de Docker), con carga vacía y un intervalo medio de 0,016 s. Solo 4 direcciones respondieron.

- **Túnel (`CU7_03`):** 30 paquetes, 15 peticiones y 15 respuestas con carga de 900 bytes, todos hacia el mismo destino, a intervalo fijo de 0,62 s, con proporción de caracteres imprimibles y de Base64 igual a 1,0.

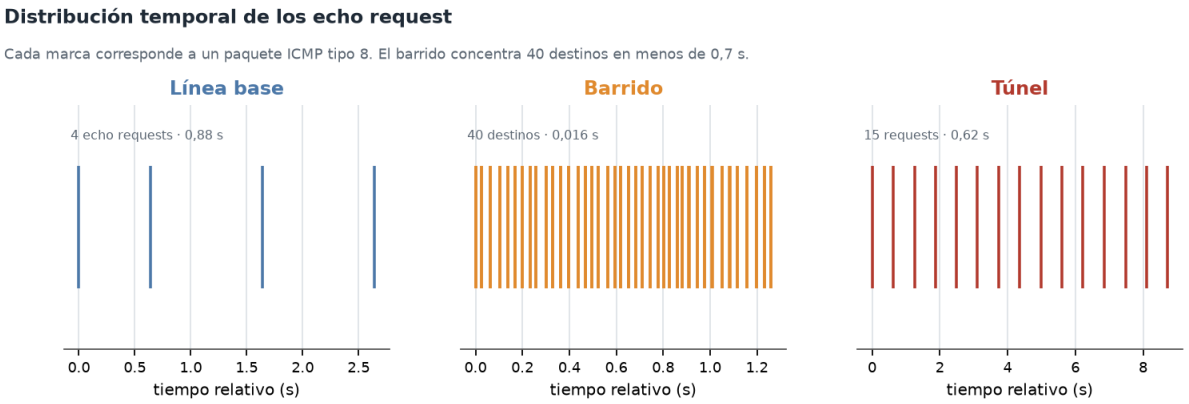


Figura 24
Distribución temporal de las peticiones de eco en los tres escenarios.

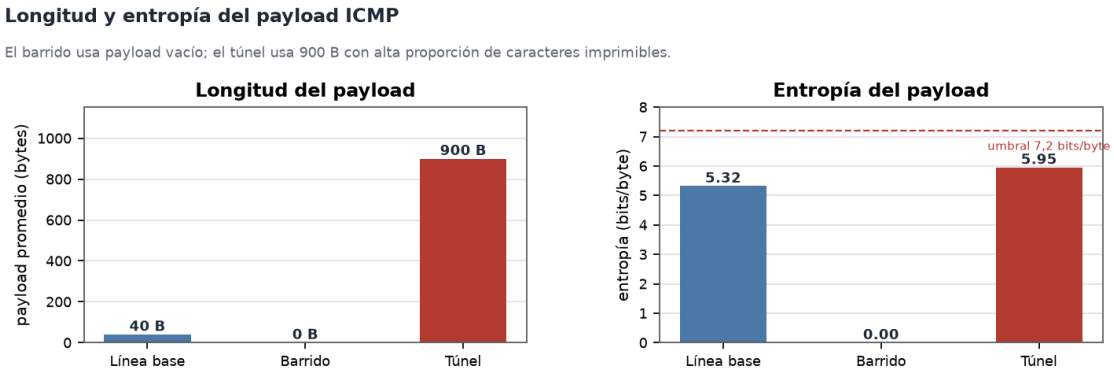


Figura 25
Longitud y entropía de la carga ICMP por escenario.

Análisis de resultados. Las tres capturas muestran perfiles claramente distintos. La línea base presenta periodicidad regular, tamaño pequeño y constante, y un único destino: es el uso legítimo de ICMP. El barrido invierte la cardinalidad de destinos en muy poco tiempo (40 destinos

en 0,7 s y un paquete cada 16 ms) con carga vacía, lo que corresponde a reconocimiento y no a diagnóstico operativo. El tercer escenario combina tres señales que, juntas, no se explican por un `ping` normal: payload muy grande y constante (900 bytes), contenido codificado en Base64 en su totalidad y cadencia fija por más de 9 segundos hacia un único host.

Conviene subrayar que la entropía observada (5,95 bits/byte) *no* supera el umbral típico de contenido cifrado o comprimido (cercano a 7,2). La carga es texto Base64, cuya entropía teórica ronda los 6 bits por carácter; por tanto, un detector basado únicamente en entropía fallaría. El indicador robusto es la combinación de longitud anómala, alta proporción de caracteres imprimibles, cadencia regular y baja diversidad de destinos. En entornos donde ICMP solo se usa para diagnóstico, esta combinación es un fuerte indicio de canal encubierto.

Alertas de Suricata 7.0.7 para el Caso 7 — evidencia de laboratorio

```
timestamp (UTC)         mensaje                                              flujo
- - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - -
16:47:16.263834  CU7 rafaga de echo requests (posible barrido ICMP)    172.28.50.10:8 -> 172.28.50.10:0
16:47:16.582768  CU7 rafaga de echo requests (posible barrido ICMP)    172.28.50.10:8 -> 172.28.50.20:0
16:47:16.875313  CU7 rafaga de echo requests (posible barrido ICMP)    172.28.50.10:8 -> 172.28.50.30:0
16:47:17.222763  CU7 rafaga de echo requests (posible barrido ICMP)    172.28.50.10:8 -> 172.28.50.40:0
16:47:23.052250  CU7 ICMP echo request con payload grande (posible tu  172.28.50.10:8 -> 172.28.50.20:0
16:47:24.910749  CU7 ICMP echo request con payload grande (posible tu  172.28.50.10:8 -> 172.28.50.20:0
16:47:26.790583  CU7 ICMP echo request con payload grande (posible tu  172.28.50.10:8 -> 172.28.50.20:0
16:47:28.651748  CU7 ICMP echo request con payload grande (posible tu  172.28.50.10:8 -> 172.28.50.20:0
16:47:30.527318  CU7 ICMP echo request con payload grande (posible tu  172.28.50.10:8 -> 172.28.50.20:0
```

Salida de fast.log al reprocesar las capturas: 4 alertas de barrido (SID 1007002) y 5 de payload grande (SID 1007001); la línea base no genera alertas.

Figura 26
Alertas de Suricata 7.0.7 al reprocesar las capturas del Caso 7.

Indicadores de detección.

- **Cardinalidad de destinos:** más de 20 destinos distintos con peticiones de eco desde un mismo origen en menos de 5 s (barrido).
- **Tamaño de carga:** peticiones de eco con más de 500 bytes de carga de forma sostenida.
- **Cadencia:** intervalo entre peticiones casi constante durante varios segundos hacia un mismo destino.

- **Contenido:** proporción de caracteres imprimibles o de Base64 cercana a 1,0 en el campo `data`.
- **Asimetría:** relación desproporcionada entre peticiones enviadas y respuestas recibidas.

Regla de detección propuesta. Las dos reglas de la Tabla 18 se implementaron en Suricata y se validaron contra las capturas. La primera detecta el barrido por umbral de peticiones; la segunda, el payload grande con umbral de tres eventos en diez segundos.

```
alert icmp 172.28.50.0/24 any -> 172.28.50.0/24 any (
  msg:"CU7 rafaga de echo requests (posible barrido ICMP)";
  itype:8; threshold:type threshold, track by_src, count 20, seconds 5;
  classtype:attempted-recon; sid:1007002; rev:1;)

alert icmp 172.28.50.0/24 any -> 172.28.50.20 any (
  msg:"CU7 ICMP echo request con payload grande (posible tunel)";
  itype:8; dsize:>500;
  threshold:type threshold, track by_src, count 3, seconds 10;
  classtype:policy-violation; sid:1007001; rev:1;)
```

Al reprocesar la línea base no se generó ninguna alerta; el barrido produjo 4 alertas (SID 1007002) y el túnel 5 alertas (SID 1007001), evidencia de que las reglas distinguen el diagnóstico legítimo de la actividad sospechosa sin marcarla como ataque.

Mitigación y defensa.

- **Permitir lo necesario:** autorizar los tipos ICMP requeridos (0, 3, 8, 11 y los tipos de ICMPv6 usados por el descubrimiento de vecinos) y limitar el resto.
- **Control de tasa:** limitar la frecuencia de peticiones de eco por origen para contener barridos y canales de baja velocidad.

- **Inspección de tamaño y contenido:** alertar ante cargas inusualmente grandes y perfiles de texto codificado; registrar el tamaño de carga en la telemetría.
- **Defensa en profundidad:** combinar IDS/IPS, segmentación y filtrado de egreso para que un túnel que logre salir no supere los controles siguientes.
- **Monitorización:** vigilar la relación peticiones/respuestas y la aparición de destinos nuevos desde equipos que normalmente no usan ICMP.

Ninguna medida debe impedir el descubrimiento de MTU ni el diagnóstico autorizado, pues un bloqueo indiscriminado de ICMP degrada la red.

Preguntas de análisis.

1. **¿Qué funciones legítimas cumple ICMP?**

   ICMP notifica errores de entrega (destino inalcanzable, tiempo excedido, redirección, necesidad de fragmentar), permite el descubrimiento de la MTU de la ruta, soporta el diagnóstico mediante eco y traza de ruta, y en IPv6 sustituye parte de la señalización de ARP con el descubrimiento de vecinos. Sin él, una red sana no puede informar a los emisores por qué un paquete no llegó.

2. **¿Qué impacto tendría bloquearlo completamente?**

   Bloquear todo ICMP rompe el descubrimiento de MTU y crea “agujeros negros” donde las conexiones grandes fallan silenciosamente; también oculta errores útiles para el diagnóstico y, en IPv6, inhabilita el descubrimiento de vecinos y la autoconfiguración. Por eso la recomendación es filtrar por tipo, tamaño y tasa, no de forma indiscriminada.

Conclusiones.

- Se verificó la integridad de las tres capturas con SHA-256 y se documentó la topología aislada del laboratorio.

- La línea base permitió definir el comportamiento legítimo de ICMP y sirvió de referencia para las demás fases.
- El barrido se identificó por la alta cardinalidad de destinos en un intervalo muy corto, con carga vacía.
- El escenario de túnel se distinguió por la combinación de carga grande, Base64 y cadencia constante; la entropía por sí sola no habría bastado.
- Las reglas propuestas se validaron con Suricata: cero alertas en la línea base y detección en las fases anómalas.
- Las limitaciones incluyen la escala reducida del laboratorio, el uso de tráfico sintético y la duplicación de paquetes por el puente virtual.

Tabla 19
Ficha de registro del hallazgo. Caso 7

Campo	**Registro**
Identificador	Caso 7 (ICMP), evidencias `01_topologia_lab.png` a `07_suricata_alertas.png`. Analista: Yader Ibraldo Quiroga Torres.
Fecha y hora	10 de noviembre de 2026, 11:47 (UTC−5); `CU7_01`, `CU7_02` y `CU7_03`.
Origen/destino	Analista `172.28.50.10` hacia la víctima `172.28.50.20` y hacia `172.28.50.1-40` en el barrido.
Observación	Tres perfiles de ICMP: diagnóstico de 40 bytes, barrido con 40 destinos y carga vacía, y túnel simulado de 900 bytes en Base64.
Hipótesis	Un uso abusivo de ICMP se manifestará por mayor cardinalidad de destinos, tamaños de carga inusuales o cadencia y contenido repetitivos.
Validación	Análisis con `tshark` y Suricata 7.0.7: sin alertas en la línea base, 4 alertas en el barrido y 5 en el túnel.
Severidad	Media el barrido y alta el túnel simulado en un entorno productivo; informativa en el laboratorio aislado.
Acción	Documentar los indicadores, proponer control de tasa e inspección de tamaño, y evitar el bloqueo indiscriminado de ICMP.
Integridad	`CU7_02`: `95c75cdf...273c2d`; `CU7_03`: `7d32a148...11c8c` (SHA-256 truncado; el valor completo está en el Anexo A).

6.8. Caso 8. Escaneo de puertos y fingerprinting de servicios

Situación

Los registros muestran intentos secuenciales contra varios puertos o servicios no habituales de un servidor de laboratorio. **Objetivo:**

Reproducir un escaneo de puertos autorizado, medir su huella en la red y en un IDS, identificar los servicios expuestos y proponer una lista de exposición con controles de reducción de superficie y reglas de detección.

Fundamento teórico:

El escaneo de puertos aprovecha el comportamiento de TCP y UDP para inferir qué servicios escucha un host. En TCP, un escaneo SYN envía un segmento con la bandera SYN: si el puerto está abierto, el servidor responde SYN-ACK; si está cerrado, responde RST. El escaneo no completa el *three-way handshake*, por lo que también se denomina *half-open*. En UDP no existe un handshake equivalente: un puerto cerrado suele responder con ICMP de puerto inalcanzable, mientras que uno abierto puede no responder, lo que produce el estado ambiguo `open|filtered`. El *fingerprinting* posterior envía sondas específicas por servicio para obtener banners y versiones (Lyon, 2026).

Procedimiento. El escenario reutiliza la red aislada del Caso 7: analista en `172.28.50.10` y víctima en `172.28.50.20`, con servicios FTP, SSH, Telnet, HTTP y dos servicios de prueba. El procedimiento fue:

1. **Integridad:** se calcularon las huellas SHA-256 de las tres capturas antes de analizarlas (Figura 27).
2. **Escaneo SYN:** se ejecutó `nmap -sS -Pn -n -p 1-1024 -min-rate 1500 -max-retries 1` y se capturó `CU8_01_syn_scan.pcap` (Figura 28).
3. **Fingerprinting:** se ejecutó `nmap -sT -sV -Pn -n -p 21,22,23,80,4444,8080 -version-all` y se capturó `CU8_02_service_scan.pcap` (Figura 29).

4. **Escaneo UDP:** se ejecutó `nmap -sU -Pn -n -p 53,123,161,500,5353` y se capturó `CU8_03_udp_scan.pcap`.

5. **Análisis de flujos:** con `tshark` se contaron paquetes SYN, SYN-ACK y RST, puertos destino únicos, duración y tasa (Figuras 30 y 31).

6. **Validación con IDS:** se reprocesó la captura SYN con Suricata 7.0.7 y las reglas locales (Figura 32).

Integridad de las capturas del Caso 8

Huellas SHA-256 calculadas antes del análisis (sha256sum sobre las copias originales).

Archivo	Tamaño	SHA-256
CU8_01_syn_scan.pcap	147.776 B	9fef801cadf8b5f1cc0cfe0496f8999c cd05dc6fb2a1a09220a4e194b555130c
CU8_02_service_scan.pcap	395.648 B	41a5fab713dbf711276a8f6098a87c4e 16e033db05c25ef31fe32f5316bf5a09
CU8_03_udp_scan.pcap	3.616 B	f1f094daf14a5bcfc7b31e8deb75f4a1 57122134e0747168d8bc4ddd36bbb89d

Figura 27
Verificación de integridad de las capturas del Caso 8 mediante SHA-256.

Resultado del escaneo SYN (nmap -sS) evidencia de laboratorio

```
# Nmap 7.95 scan initiated Tue Nov 10 16:58:06 2026 as: nmap -sS -Pn -n -p 1-1024 --min-rate 1500 --max-retries 1 -oN
    /lab/case8_syn_scan.txt 172.28.50.20
Nmap scan report for 172.28.50.20
Host is up (0.000058s latency).
Not shown: 1020 closed tcp ports (reset)
PORT   STATE SERVICE
21/tcp open  ftp
22/tcp open  ssh
23/tcp open  telnet
80/tcp open  http
MAC Address: 06:CD:42:90:94:B7 (Unknown)

# Nmap done at Tue Nov 10 16:58:07 2026 -- 1 IP address (1 host up) scanned in 0.31 seconds
```

Nmap 7.95 sobre 172.28.50.20, puertos 1-1024, --min-rate 1500. Cuatro puertos abiertos y 1020 cerrados.

Figura 28
Resultado del escaneo SYN sobre los puertos 1–1024 de la víctima.

Fingerprinting de servicios (nmap -sT -sV) evidencia de laboratorio

```
# Nmap 7.95 scan initiated Tue Nov 10 16:58:10 2026 as: nmap -sT -sV -Pn -n -p 21,22,23,80,4444,8080 --version-all -oN
    /lab/case8_service_scan.txt 172.28.50.20
Nmap scan report for 172.28.50.20
Host is up (0.0012s latency).

PORT     STATE SERVICE    VERSION
21/tcp   open  ftp
22/tcp   open  ssh        OpenSSH 9.7 (protocol 2.0)
23/tcp   open  telnet
80/tcp   open  http       nginx
4444/tcp open  krb524?
8080/tcp open  http-proxy LabHTTP/0.9
4 services unrecognized despite returning data. If you know the service/version, please submit the following
    fingerprints at https://nmap.org/cgi-bin/submit.cgi?new-service :

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Tue Nov 10 16:58:16 2026 -- 1 IP address (1 host up) scanned in 6.67 seconds
```

Versiones detectadas en los seis puertos abiertos. Los fingerprints extensos se omitieron para mantener la legibilidad.

Figura 29
Detección de versiones y banners de los servicios expuestos.

Resultados obtenidos. La Tabla 20 resume las métricas de las tres capturas. El escaneo SYN generó 2052 paquetes TCP en 59 ms, con 1024 SYN, 4 SYN-ACK y 1020 RST; es decir, 1024 puertos únicos, de los cuales solo cuatro estaban abiertos (21, 22, 23 y 80). La tasa media fue de aproximadamente 17 400 SYN por segundo (34 817 paquetes TCP por segundo si se cuentan también las respuestas).

Tabla 20
Métricas de las capturas del Caso 8

Captura	Paquetes	Puertos	Duración	Observación
`CU8_01_syn_scan`	2052 TCP	1024	59 ms	1024 SYN, 4 SYN-ACK, 1020 RST.
`CU8_02_service_scan`	4214 TCP	6	6,67 s	328 200 bytes; banners y versiones.
`CU8_03_udp_scan`	28 UDP	5	1,75 s	7 ICMP de puerto inalcanzable.

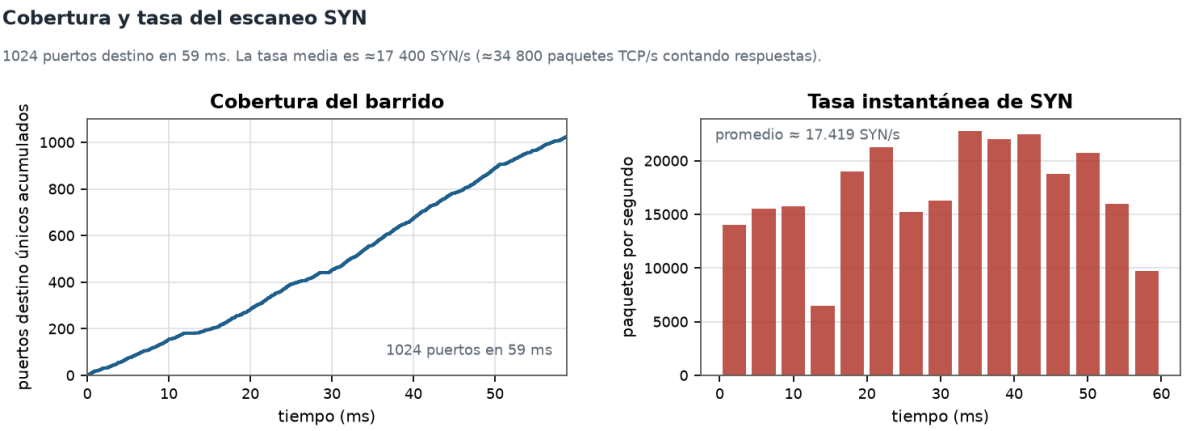


Figura 30

Cobertura acumulada de puertos y tasa instantánea del escaneo SYN.

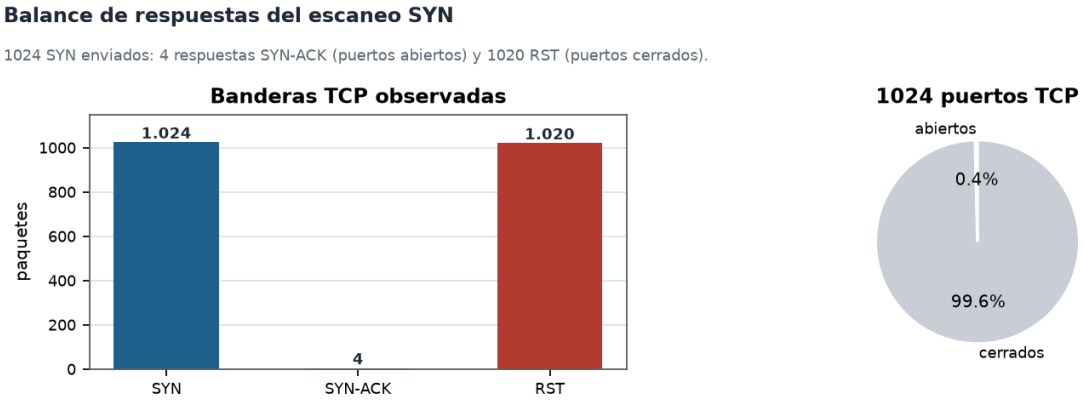


Figura 31

Balance de banderas TCP y proporción de puertos abiertos frente a cerrados.

Análisis de resultados. El escaneo SYN deja una huella muy reconocible: una ráfaga de segmentos SYN con puertos destino crecientes, seguida de RST para los puertos cerrados y de SYN-ACK para los abiertos. La proporción de RST (1020 de 1024 puertos, 99,6 %) y la ausencia de un handshake completo confirman el carácter *half-open* del barrido. La tasa instantánea, superior a 20 000 SYN/s en varios intervalos, es muy superior a la de un cliente legítimo y explica por qué un umbral simple de 30 SYN en 10 s detecta el evento.

El escaneo de servicios, en cambio, sí completa conexiones y solicita banners. Eso permite identificar versiones concretas: OpenSSH 9.7 en el puerto 22, nginx en el 80, `Laboratorio FTP`

`1.0` en el 21, `Laboratorio Telnet 0.9` en el 23 y `LabHTTP/0.9` en el 8080. El puerto 4444 respondió con `LAB-SVC/0.1 ready`, un servicio no estándar que Nmap no pudo clasificar y etiquetó como `krb524?`; esa ambigüedad es una limitación del fingerprinting y, a la vez, una señal de que el servicio no debería estar expuesto sin justificación.

El escaneo UDP fue mucho menos concluyente: 53, 123, 161 y 5353 respondieron con ICMP de puerto inalcanzable (cerrados), mientras que el 500 quedó en `open|filtered` porque no hubo respuesta. La ausencia de respuesta no prueba que el puerto esté abierto: puede deberse a un filtrado silencioso.

Alertas de Suricata para el escaneo SYN (extracto) — evidencia de laboratorio

```
timestamp (UTC)          mensaje                                          flujo
- - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - -
16:58:06.976939  CU8 escaneo TCP SYN (muchos SYNs por origen)    172.28.50.10:52174 -> 172.28.50.20:1000
16:58:06.979289  CU8 escaneo TCP SYN (muchos SYNs por origen)    172.28.50.10:52174 -> 172.28.50.20:344
16:58:06.981124  CU8 escaneo TCP SYN (muchos SYNs por origen)    172.28.50.10:52174 -> 172.28.50.20:492
16:58:06.983225  CU8 escaneo TCP SYN (muchos SYNs por origen)    172.28.50.10:52174 -> 172.28.50.20:833
16:58:06.984890  CU8 escaneo TCP SYN (muchos SYNs por origen)    172.28.50.10:52174 -> 172.28.50.20:164
16:58:06.986860  CU8 escaneo TCP SYN (muchos SYNs por origen)    172.28.50.10:52174 -> 172.28.50.20:401
16:58:06.991163  CU8 escaneo TCP SYN (muchos SYNs por origen)    172.28.50.10:52174 -> 172.28.50.20:86
16:58:06.992638  CU8 escaneo TCP SYN (muchos SYNs por origen)    172.28.50.10:52174 -> 172.28.50.20:785
16:58:06.994455  CU8 escaneo TCP SYN (muchos SYNs por origen)    172.28.50.10:52174 -> 172.28.50.20:108
16:58:06.995763  CU8 escaneo TCP SYN (muchos SYNs por origen)    172.28.50.10:52174 -> 172.28.50.20:829
16:58:06.997175  CU8 escaneo TCP SYN (muchos SYNs por origen)    172.28.50.10:52174 -> 172.28.50.20:302
16:58:06.998723  CU8 escaneo TCP SYN (muchos SYNs por origen)    172.28.50.10:52174 -> 172.28.50.20:990
16:58:06.999962  CU8 escaneo TCP SYN (muchos SYNs por origen)    172.28.50.10:52174 -> 172.28.50.20:796
16:58:07.002604  CU8 escaneo TCP SYN (muchos SYNs por origen)    172.28.50.10:52174 -> 172.28.50.20:533
16:58:07.005002  CU8 escaneo TCP SYN (muchos SYNs por origen)    172.28.50.10:52174 -> 172.28.50.20:595
16:58:07.006562  CU8 escaneo TCP SYN (muchos SYNs por origen)    172.28.50.10:52174 -> 172.28.50.20:736
16:58:07.007928  CU8 escaneo TCP SYN (muchos SYNs por origen)    172.28.50.10:52174 -> 172.28.50.20:429
16:58:07.009023  CU8 escaneo TCP SYN (muchos SYNs por origen)    172.28.50.10:52174 -> 172.28.50.20:536

— respuestas RST (regla 1008002) —

16:58:06.977631  CU8 respuestas RST multiples (barrido de puert  172.28.50.20:849 -> 172.28.50.10:52174
16:58:06.979548  CU8 respuestas RST multiples (barrido de puert  172.28.50.20:214 -> 172.28.50.10:52174
16:58:06.981423  CU8 respuestas RST multiples (barrido de puert  172.28.50.20:779 -> 172.28.50.10:52174
16:58:06.983563  CU8 respuestas RST multiples (barrido de puert  172.28.50.20:472 -> 172.28.50.10:52174
16:58:06.985050  CU8 respuestas RST multiples (barrido de puert  172.28.50.20:395 -> 172.28.50.10:52174
16:58:06.988825  CU8 respuestas RST multiples (barrido de puert  172.28.50.20:428 -> 172.28.50.10:52174
16:58:06.991335  CU8 respuestas RST multiples (barrido de puert  172.28.50.20:228 -> 172.28.50.10:52174
16:58:06.992800  CU8 respuestas RST multiples (barrido de puert  172.28.50.20:560 -> 172.28.50.10:52174
16:58:06.994698  CU8 respuestas RST multiples (barrido de puert  172.28.50.20:406 -> 172.28.50.10:52174
16:58:06.996014  CU8 respuestas RST multiples (barrido de puert  172.28.50.20:853 -> 172.28.50.10:52174
16:58:06.997418  CU8 respuestas RST multiples (barrido de puert  172.28.50.20:365 -> 172.28.50.10:52174
16:58:06.998936  CU8 respuestas RST multiples (barrido de puert  172.28.50.20:1019 -> 172.28.50.10:52174
16:58:07.000382  CU8 respuestas RST multiples (barrido de puert  172.28.50.20:339 -> 172.28.50.10:52174
16:58:07.002882  CU8 respuestas RST multiples (barrido de puert  172.28.50.20:514 -> 172.28.50.10:52174
16:58:07.005168  CU8 respuestas RST multiples (barrido de puert  172.28.50.20:343 -> 172.28.50.10:52174
16:58:07.006722  CU8 respuestas RST multiples (barrido de puert  172.28.50.20:41 -> 172.28.50.10:52174
16:58:07.008151  CU8 respuestas RST multiples (barrido de puert  172.28.50.20:892 -> 172.28.50.10:52174
16:58:07.009227  CU8 respuestas RST multiples (barrido de puert  172.28.50.20:283 -> 172.28.50.10:52174
```

34 coincidencias de la regla 1008001 y 34 de la 1008002; se muestran las primeras 18 de cada una. Umbral: 30 eventos por origen en 10 s.

Figura 32
Alertas de Suricata 7.0.7 para el escaneo SYN (extracto de `fast.log`).

Indicadores de detección.

- **Ráfaga de SYN:** más de 30 segmentos SYN desde un mismo origen en 10 s.

- **Barrido de puertos:** muchos puertos destino únicos y crecientes en un intervalo corto.
- **Relación SYN/RST:** predominio de RST sobre SYN-ACK, señal de puertos cerrados.
- **Fingerprinting:** conexiones completas seguidas de banners o cadenas de versión en varios puertos.
- **UDP e ICMP:** ráfaga de datagramas UDP con respuestas ICMP de puerto inalcanzable.

Regla de detección propuesta. Las reglas se validaron con Suricata: 34 alertas de la regla 1008001 y 34 de la regla 1008002 sobre `CU8_01_syn_scan.pcap`. El umbral de 30 eventos por origen en 10 s evita que un cliente que abre varias conexiones normales dispare la alerta.

```
alert tcp 172.28.50.10 any -> 172.28.50.20 any (
  msg:"CU8 escaneo TCP SYN (muchos SYNs por origen)"; flags:S;
  threshold:type threshold, track by_src, count 30, seconds 10;
  classtype:attempted-recon; sid:1008001; rev:1;)

alert tcp 172.28.50.20 any -> 172.28.50.10 any (
  msg:"CU8 respuestas RST multiples (barrido de puertos)"; flags:R*;
  threshold:type threshold, track by_dst, count 30, seconds 10;
  classtype:attempted-recon; sid:1008002; rev:1;)
```

Lista de exposición y endurecimiento. La Tabla 21 clasifica los servicios observados. La decisión de exposición debe justificarse por necesidad operativa y no por comodidad de instalación.

Tabla 21
Lista de exposición de servicios propios

Puerto	Servicio	Versión	¿Expuesto?	Justificación	Control propuesto
21	FTP	Laboratorio FTP 1.0	Sí	Protocolo heredado sin cifrado.	Deshabilitar o migrar a SFTP/FTPS.
22	SSH	OpenSSH 9.7	Sí	Administración remota.	Restringir por origen, solo claves y MFA.
23	Telnet	Laboratorio Telnet 0.9	Sí	Credenciales en claro.	Deshabilitar de forma definitiva.
80	HTTP	nginx	Sí	Publicación web.	Redirigir a HTTPS y aplicar WAF.
4444	Desconocido	LAB-SVC/0.1	Sí	Servicio de prueba sin justificación.	Cerrar salvo necesidad documentada.
8080	HTTP	LabHTTP/0.9	Sí	Servicio de pruebas.	Restringir a la red de laboratorio.

Mitigación y defensa.

- **Reducción de superficie:** apagar servicios que no se usan y sustituir FTP/Telnet por SFTP/SSH.
- **Segmentación y firewall:** política de denegación por defecto y apertura solo desde redes y usuarios autorizados.
- **Control de tasa y bloqueo temporal:** limitar conexiones por origen y aplicar bloqueo con revisión ante barridos sostenidos.
- **Endurecimiento:** minimizar banners, actualizar versiones, usar TLS en los servicios publicados y revisar privilegios.
- **Monitorización:** correlacionar alertas de IDS con inventario de servicios y con ventanas de mantenimiento.
- **Pruebas autorizadas:** programar escaneos desde direcciones conocidas y documentarlos para separar el monitoreo legítimo de un ataque.

Preguntas de análisis.

1. **¿Qué limitaciones tiene atribuir un escaneo a una sola IP?**

   Una dirección IP no identifica de forma única a una persona o equipo: puede estar detrás de NAT o de un proxy, puede haber sido asignada por DHCP a otro host, puede estar suplantada mediante *spoofing* o formar parte de una botnet distribuida. La atribución requiere correlacionar flujos, horarios, registros de autenticación, inventario de activos y, cuando exista, evidencia del proveedor; la IP por sí sola es solo un punto de partida.

2. **¿Cómo se reducen los falsos positivos por monitoreo autorizado?**

   Con listas de escáneres autorizados, ventanas de mantenimiento, autenticación de los escaneos, umbrales calibrados con la línea base, supresión temporal con caducidad y correlación con el sistema de gestión de cambios. También ayuda distinguir el escaneo de inventario (puertos conocidos y periodicidad estable) del escaneo oportunista (puertos aleatorios y ráfaga anómala).

Conclusiones.

- El escaneo SYN se detectó con precisión por la ráfaga de segmentos y la proporción de RST; las dos reglas de Suricata se validaron con 34 alertas cada una.
- El fingerprinting identificó versiones concretas y reveló un servicio no estándar en el puerto 4444 que no debería estar expuesto.
- El escaneo UDP mostró su ambigüedad inherente: la falta de respuesta no equivale a puerto abierto.
- La lista de exposición permite priorizar el cierre de FTP, Telnet y servicios de prueba, y restringir SSH y HTTP.
- Las limitaciones incluyen el tamaño reducido del laboratorio, la latencia casi nula de la red virtual y la ausencia de técnicas de evasión.

Tabla 22
Ficha de registro del hallazgo. Caso 8

Campo	Registro
Identificador	Caso 8 (escaneo de puertos), evidencias `01_hashes_sha256.png` a `06_suricata_alertas.png`. Analista: Yader Ibraldo Quiroga Torres.
Fecha y hora	10 de noviembre de 2026, 11:58 (UTC−5).
Origen/destino	Analista `172.28.50.10` hacia la víctima `172.28.50.20`.
Observación	Escaneo SYN de 1024 puertos en 59 ms, fingerprinting de seis servicios y escaneo UDP de cinco puertos.
Hipótesis	Un escaneo de puertos produce una ráfaga de SYN con muchos puertos destino y una proporción alta de RST, y el fingerprinting genera banners identificables.
Validación	`tshark` confirmó 1024 SYN, 4 SYN-ACK y 1020 RST; Suricata generó 34 alertas por SYN y 34 por RST.
Severidad	Media: exposición de FTP, Telnet y un servicio no justificado en el puerto 4444.
Acción	Cerrar servicios innecesarios, restringir SSH y HTTP, y mantener las reglas de detección con umbrales calibrados.
Integridad	`CU8_01`: `9fef801c...55130c` (SHA-256 truncado; el valor completo está en el Anexo A).

6.9. Caso 9. Priorización y correlación de alertas con IA y SIEM

Situación

El centro de monitoreo recibe múltiples alertas que deben agruparse y priorizarse.

Procedimiento.

- Normalizar eventos de firewall, servidor, Zeek/Suricata y sistema operativo; eliminar duplicados sin perder trazabilidad.
- Definir características agregadas por host y ventana temporal, y probar un detector de anomalías con datos controlados.
- Usar un LLM únicamente para resumir alertas anonimizadas y sugerir el triage; verificar toda recomendación contra la evidencia.

Indicadores que deben buscarse. Alertas correlacionadas por host/tiempo, puntuación de riesgo explicable y señales convergentes en varias fuentes.

Mitigación y defensa. Revisión humana antes de acciones disruptivas; control de acceso a los registros; evaluación de sesgo y deriva; registro de decisiones y posibilidad de reversión.

Evidencias que se entregan. Diagrama del pipeline, ejemplo de alerta enriquecida, criterios de prioridad y registro de validación humana.

Preguntas de análisis.

1. ¿Cómo explicar una alerta a un analista?

2. ¿Qué riesgo supone automatizar bloqueos basados solo en una puntuación?

Tabla 23
Fuentes de eventos del pipeline de correlación

Fuente	Tipo de evento	Formato	Responsable
Firewall			
Servidor web			
Zeek / Suricata			
Sistema operativo			
SIEM / Wazuh			

Tabla 24
Ficha de registro del hallazgo. Caso 9

Campo	Registro
Identificador	
Fecha y hora	
Origen/destino	
Observación	
Hipótesis	
Validación	
Severidad	
Acción	
Integridad	

6.10. Caso 10. Mensajería XMPP: interceptación y errores de TLS

Situación

Se investiga si la comunicación entre clientes y servidor de mensajería está correctamente protegida, y qué ocurre cuando el certificado es inválido o la validación se desactiva. **Objetivo:** Comparar un servidor XMPP deliberadamente débil con uno endurecido, comprobar qué parte de la conversación queda expuesta en una captura pasiva, validar el comportamiento del cliente frente a un certificado vencido o suplantado y proponer un checklist de configuración TLS con controles verificables.

Fundamento Teórico:

XMPP (*Extensible Messaging and Presence Protocol*) define un flujo XML sobre TCP y utiliza STARTTLS para negociar una sesión TLS antes de autenticar (Saint-Andre, 2011). TLS 1.3 (Rescorla, 2018) proporciona confidencialidad e integridad en el tramo cliente-servidor y, cuando el cliente valida el certificado, autentica al servidor. Sin embargo, TLS termina en el servidor: el operador de ese servidor puede leer los mensajes, y los archivos de archivo (MAM) o las copias de respaldo pueden conservarlos en claro. La autenticación SASL `PLAIN` transmite usuario y contraseña codificados en Base64, que es una codificación reversible y no un cifrado; sin TLS, esa credencial queda expuesta en la red.

Procedimiento. Se desplegaron dos servidores Prosody 0.11.9 en la red aislada `172.28.50.0/24` (Figura 33): el inseguro en `172.28.50.30`, con certificado autofirmado y vencido, autenticación en claro permitida, registro abierto y archivo MAM; y el endurecido en `172.28.50.31`, con certificado firmado por una CA local, TLS 1.2 o superior, administración en *loopback* y registro deshabilitado. El cliente se ejecutó desde el analista `172.28.50.10` con `slixmpp` y OpenSSL.

1. **Integridad:** se calcularon las huellas SHA-256 de las siete capturas (Figura 34).
2. **Negociación STARTTLS:** se capturaron `CU10_01_xmpp_insecure.pcap` y `CU10_02_xmpp_secure.pcap` y se comparó la secuencia XMPP/TLS (Figura 35).

3. **Certificados:** se inspeccionaron ambos certificados con `openssl s_client` y se registraron vigencia, nombre, cadena y código de verificación (Figuras 36 y 37).

4. **Contenido cifrado:** se envió un mensaje real sobre TLS y se buscó su cuerpo y la contraseña en la captura `CU10_03_xmpp_message.pcap` (Figura 38).

5. **Sesión sin TLS:** se capturó `CU10_05_xmpp_plaintext.pcap` con autenticación `PLAIN` y mensaje en claro (Figura 39).

6. **Archivo MAM:** se revisó el archivo del servidor y se comprobó si el cuerpo del mensaje queda legible (Figura 40).

7. **Validación frente a MITM:** se levantó un intermediario con certificado autofirmado y se comparó el resultado con y sin validación (Figura 41).

8. **HTTPS y IDS:** se capturaron sesiones HTTPS con TLS 1.3 y TLS 1.2 para comprobar qué metadatos ve un IDS pasivo y se validó la regla de certificado (Figuras 42 y 43).

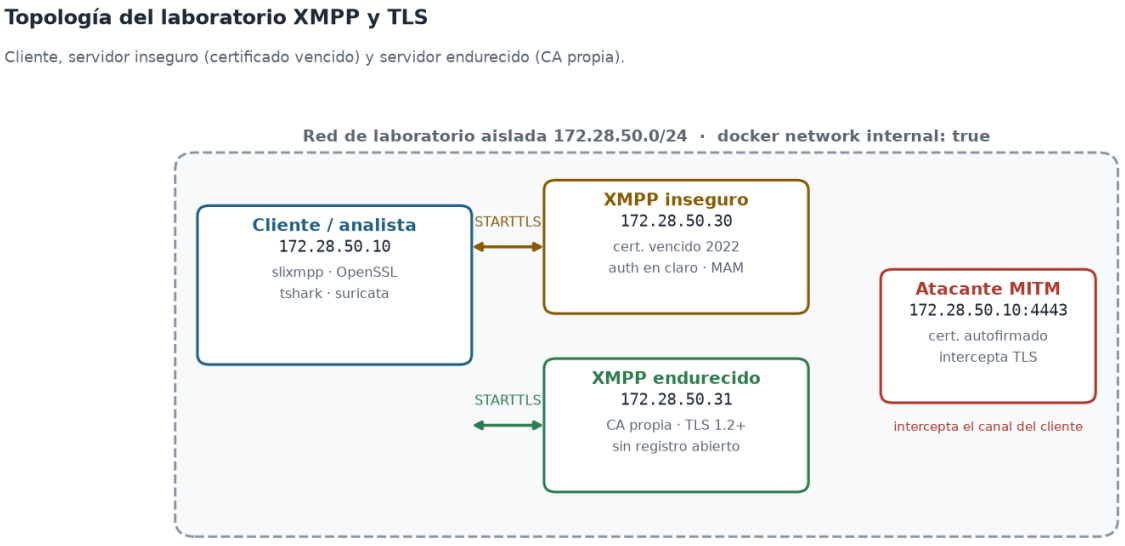


Figura 33
Topología del laboratorio XMPP y TLS.

Integridad de las capturas del Caso 10

Huellas SHA-256 de las siete capturas utilizadas en el análisis.

Archivo	Tamaño	SHA-256
CU10_01_xmpp_insecure.pcap	5.105 B	3400d740daf0d9f3d75fe6ccdc69d23f 24e0984a6ec67ebfa0a1853095b87bda
CU10_02_xmpp_secure.pcap	5.362 B	3e2f0b6938aa4b06bcd9e1762c4183db 5471acaf3b87603198394e902b6fef6d
CU10_03_xmpp_message.pcap	21.373 B	267df8e580e63a9f0202be4667ba0500 1b8ac695b05b56c18edf288f4eaf1b66
CU10_05_xmpp_plaintext.pcap	4.346 B	79c12243f3a5fcf51694e7edf355e2cb 80d2fc52bf8c1e535b15e11ebe7c1c76
CU10_06_https_insecure.pcap	9.319 B	62315796d2ba7687ad3247b2d9b0d176 838924bec228622e94ebb27773e86dad
CU10_07_https_tls12_insecure.pcap	8.442 B	163f557c1cd60c86efbc7c259caeaa2e ade2ae6c973ae32b35db8fff1a5479ea
CU10_08_https_tls12_secure.pcap	8.864 B	5679faae98540281908ff5e6fbddbda5 d2b8e2e7aedc9f085fb354dc3f331afa

Figura 34

Verificación de integridad de las capturas del Caso 10 mediante SHA-256.

Negociación STARTTLS en ambos servidores evidencia de laboratorio

```
INSECURO 172.28.50.30 (certificado vencido)
frame  time_rel     origen          destino         protocolo  información
- - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - -
   10  0.008621     172.28.50.10    172.28.50.30    TLS         Client Hello (SNI=lab.local)
   11  0.008881     172.28.50.30    172.28.50.10    TLS         Hello Retry Request, Change Cipher Spec
   12  0.009728     172.28.50.10    172.28.50.30    TLS         Change Cipher Spec, Client Hello (SNI=lab.lo
   13  0.016574     172.28.50.30    172.28.50.10    TLS         Server Hello, Application Data, Application

ENDURECIDO 172.28.50.31 (CA propia)
frame  time_rel     origen          destino         protocolo  información
- - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - -
   10  0.005782     172.28.50.10    172.28.50.31    TLS         Client Hello (SNI=lab.local)
   11  0.006427     172.28.50.31    172.28.50.10    TLS         Hello Retry Request, Change Cipher Spec
   12  0.007913     172.28.50.10    172.28.50.31    TLS         Change Cipher Spec, Client Hello (SNI=lab.lo
   13  0.015605     172.28.50.31    172.28.50.10    TLS         Server Hello, Application Data, Application

Secuencia XMPP previa al TLS (captura insegura):
  4  0.007062  172.28.50.10 -> 172.28.50.30  STREAM > lab.local
  6  0.007607  172.28.50.30 -> 172.28.50.10  STREAM < lab.local
  8  0.007755  172.28.50.10 -> 172.28.50.30  STARTTLS
  9  0.008110  172.28.50.30 -> 172.28.50.10  PROCEED
```

Ambos servidores negocian TLS 1.3 tras STARTTLS/PROCEED. La diferencia no está en la versión, sino en el certificado y en la validación del cliente.

Figura 35

Negociación STARTTLS en el servidor inseguro y en el endurecido.

Resultados obtenidos. Ambos servidores negocian TLS 1.3 tras el intercambio `STARTTLS`/`PROCEED`: la diferencia no está en la versión, sino en el certificado y en la validación del cliente. El servidor inseguro presenta un certificado `CN=localhost`, autofirmado y vencido el 13 de mayo de 2022; OpenSSL reporta `verify error:num=18` (autofirmado) y `num=10` (ven-

cido), con código de retorno 10. El servidor endurecido presenta una cadena completa hasta la CA local, `CN=lab.local` con SAN para `lab.local`, `localhost` y las direcciones del laboratorio, válido hasta 2029, y código de retorno 0.

Certificado del servidor XMPP inseguro — evidencia de laboratorio

```
Connecting to 172.28.50.30
CONNECTED(00000003)
depth=0 CN=localhost
verify error:num=18:self-signed certificate
depth=0 CN=localhost
verify error:num=10:certificate has expired
notAfter=May 13 14:26:42 2022 GMT
depth=0 CN=localhost
notAfter=May 13 14:26:42 2022 GMT
 0 s:CN=localhost
   i:CN=localhost
   a:PKEY: rsaEncryption, 2048 (bit); sigalg: RSA-SHA256
   v:NotBefore: May 13 14:26:42 2021 GMT; NotAfter: May 13 14:26:42 2022 GMT
subject=CN=localhost
issuer=CN=localhost
Server Temp Key: ECDH, secp384r1, 384 bits
Verification error: certificate has expired
New, TLSv1.3, Cipher is TLS_AES_256_GCM_SHA384
Verify return code: 10 (certificate has expired)
    Protocol  : TLSv1.3
    Verify return code: 10 (certificate has expired)
```

openssl s_client contra 172.28.50.30: CN=localhost, autofirmado, vigencia 2021-05-13 a 2022-05-13 (vencido).

Figura 36
Certificado autofirmado y vencido del servidor XMPP inseguro.

Certificado del servidor XMPP endurecido — evidencia de laboratorio

```
Connecting to 172.28.50.31
CONNECTED(00000003)
depth=1 C=CO, O=Laboratorio Academico, CN=Laboratorio CA
depth=0 C=CO, O=Laboratorio Academico, CN=lab.local
 0 s:C=CO, O=Laboratorio Academico, CN=lab.local
   i:C=CO, O=Laboratorio Academico, CN=Laboratorio CA
   a:PKEY: rsaEncryption, 2048 (bit); sigalg: RSA-SHA256
   v:NotBefore: Nov 10 16:40:30 2026 GMT; NotAfter: Feb 12 16:40:30 2029 GMT
subject=C=CO, O=Laboratorio Academico, CN=lab.local
issuer=C=CO, O=Laboratorio Academico, CN=Laboratorio CA
Server Temp Key: ECDH, secp384r1, 384 bits
Verification: OK
New, TLSv1.3, Cipher is TLS_AES_256_GCM_SHA384
Verify return code: 0 (ok)
    Protocol  : TLSv1.3
    Verify return code: 0 (ok)
```

openssl s_client contra 172.28.50.31 con -CAfile: cadena completa, CN=lab.local, Verify return code 0 (ok).

Figura 37
Certificado firmado por la CA local en el servidor XMPP endurecido.

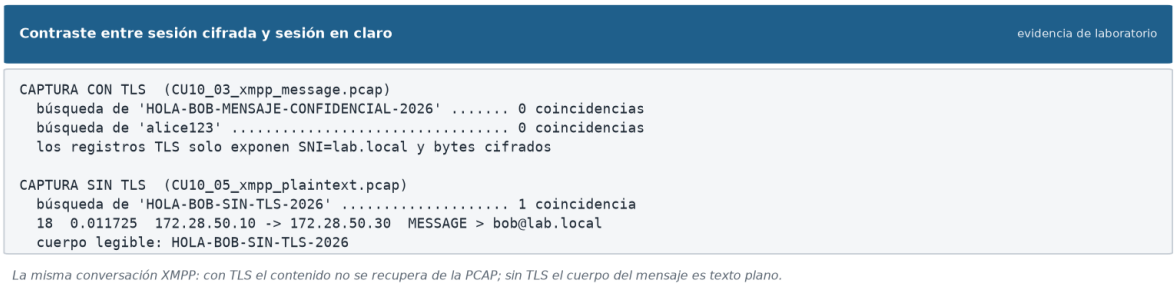


Figura 38
Contraste entre una sesión XMPP cifrada y una sesión sin TLS.

- **Sesión cifrada (`CU10_03`):** el cuerpo `HOLA-BOB-MENSAJE-CONFIDENCIAL-2026` y la contraseña `alice123` produjeron cero coincidencias en la PCAP. Solo se observan el SNI `lab.local` y registros TLS cifrados.
- **Sesión sin TLS (`CU10_05`):** la autenticación viaja como `AGFsaWNlAGFsaWNlMTIz`, que decodifica a `\x00alice\x00alice123`, y el cuerpo `HOLA-BOB-SIN-TLS-2026` aparece legible en la trama 18.
- **Archivo MAM:** el archivo `/var/lib/prosody/lab%2elocal/archive/alice.list` contiene el cuerpo completo en claro, junto con remitente, destinatario y marca de tiempo.

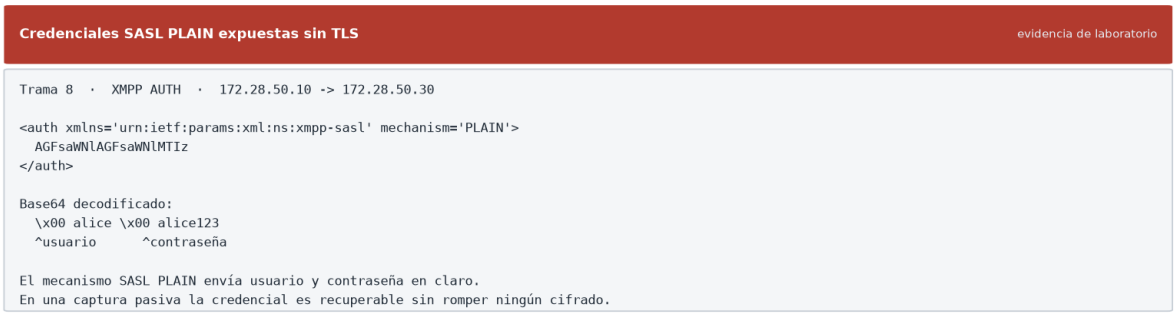


Figura 39
Credenciales SASL `PLAIN` expuestas en una sesión sin TLS.

Mensaje en claro en el archivo MAM del servidor evidencia de laboratorio

```
Archivo /var/lib/prosody/lab%2elocal/archive/alice.list

item({
    {
        "HOLA-BOB-MENSAJE-CONFIDENCIAL-2026";
        ["attr"] = {};
        ["name"] = "body";
    };
    ["with"] = "bob@lab.local";
    ["when"] = 1794329103;
    ["key"] = "NVQLMmeoCvdzLiFu";
    ["attr"] = {
        ["from"] = "alice@lab.local/nC8cE7_d";
        ["stamp_legacy"] = "20261110T16:45:03";
        ["type"] = "chat";
        ["stamp"] = "2026-11-10T16:45:03Z";
        ["xml:lang"] = "en";
        ["to"] = "bob@lab.local";
        ["id"] = "da73cfff149a48ed9df9ec1a6357fe8c";
    };
    ["name"] = "message";
});
item({
    {
        "HOLA-BOB-MENSAJE-CONFIDENCIAL-2026";
        ["attr"] = {};
```

Prosody archiva el cuerpo del mensaje sin cifrado adicional: el operador del servidor puede leer todo el historial.

Figura 40
Mensaje en claro en el archivo MAM del servidor Prosody.

Análisis de resultados. TLS cumple su función: en la captura cifrada no se recupera ni el cuerpo ni la contraseña, y la sesión no puede alterarse sin romper la integridad. Pero TLS solo protege el tramo hasta el servidor. El archivo MAM demuestra que el operador del servidor conserva el historial en claro, de modo que un TLS correcto no equivale a confidencialidad de extremo a extremo. La protección real frente al propio servidor exige cifrado de extremo a extremo (por ejemplo, OMEMO), que no se configuró en este laboratorio.

La comparación de certificados explica por qué la validación es imprescindible. Frente a un intermediario con certificado autofirmado `CN=lab.local`, OpenSSL sin validación completa el handshake (`exit 0`) y entrega el certificado; con `-CAfile` y `-verify_return_error`, aborta con `exit 1` y `certificate verify failed`. Un cliente XMPP que no valide el certificado queda expuesto a interceptación, aunque la sesión “se vea” cifrada.

La captura HTTPS añade un matiz relevante para la detección: en TLS 1.3 el mensaje de certificado viaja cifrado, por lo que un IDS pasivo solo observa el SNI; en TLS 1.2 el certificado es visible y la regla basada en `tls.cert_subject` puede alertar. Esto no significa que TLS 1.3 sea

más débil, sino que la inspección pasiva dispone de menos metadatos y requiere otras fuentes (logs del servidor, sensores con terminación TLS o telemetría del endpoint).

Validación de certificado frente a un MITM

OpenSSL conectado al intermediario 172.28.50.10:4443 con certificado autofirmado CN=lab.local.

Escenario	Comando	Resultado	Handshake
`Sin validar`	s_client -connect 172.28.50.10:4443	exit 0 · Verify return code 18	Completa
`Validando`	s_client -CAfile ca.crt -verify_return_error	exit 1 · certificate verify failed	Aborta

Figura 41
Resultado del handshake frente a un intermediario, con y sin validación del certificado.

Versiones TLS aceptadas por cada servidor

Pruebas con openssl s_client restringiendo la versión (-tls1, -tls1_1, -tls1_2, -tls1_3).

Versión	Servidor inseguro	Servidor endurecido	Observación
`TLS 1.0`	Rechazada	Rechazada	alert protocol version (70)
`TLS 1.1`	Rechazada	Rechazada	alert protocol version (70)
`TLS 1.2`	Aceptada	Aceptada	certificado vencido / válido
`TLS 1.3`	Aceptada	Aceptada	certificado vencido / válido

Figura 42
Versiones TLS aceptadas por cada servidor.

Indicadores de detección.

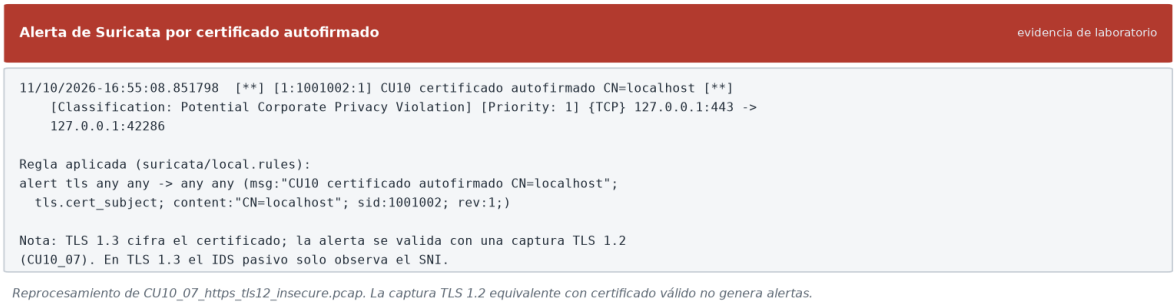
- Certificados vencidos, autofirmados o con nombre que no coincide con el servicio (`CN=localhost` para `lab.local`).
- Uso de `PLAIN` o autenticación sin TLS en XMPP.
- Puertos de administración o BOSH expuestos más allá de *loopback*.
- Registro abierto y archivo MAM con cuerpos en claro.

- Clientes que aceptan certificados inválidos o desactivan la validación.
- Sesiones XMPP sin `STARTTLS` o con caída posterior a texto claro.

Regla de detección propuesta. La regla de certificado se validó con Suricata 7.0.7 sobre `CU10_07_https_tls12_insecure.pcap`: una alerta por `CN=localhost`. La captura equivalente con certificado válido no generó alertas. También se propone una regla para BOSH sobre HTTP sin cifrar.

```
alert tls any any -> any any (
  msg:"CU10 certificado autofirmado CN=localhost"; tls.cert_subject;
  content:"CN=localhost"; classtype:policy-violation; sid:1001002; rev:1;)

alert tcp any any -> any 5280 (
  msg:"CU10 BOSH XMPP sobre HTTP sin cifrar"; flow:to_server,established;
  content:"POST"; content:"/http-bind"; distance:0;
  classtype:policy-violation; sid:1001003; rev:1;)
```



Reprocesamiento de CU10_07_https_tls12_insecure.pcap. La captura TLS 1.2 equivalente con certificado válido no genera alertas.

Figura 43
Alerta de Suricata por certificado autofirmado en una captura TLS 1.2.

Mitigación y defensa.

- **Certificado confiable:** emitir el certificado con una CA reconocida, incluir el nombre real en CN/SAN y renovarlo antes de su vencimiento.

- **TLS obligatorio:** exigir TLS 1.2 o superior, deshabilitar versiones heredadas y rechazar autenticación en claro.
- **Validación en el cliente:** no permitir la aceptación de certificados inválidos; considerar *pinning* en clientes propios.
- **Superficie administrativa:** limitar administración y BOSH a *loopback* o a una red de gestión, y deshabilitar el registro abierto.
- **Datos en reposo:** cifrar el archivo MAM, definir retención y acceso mínimo; para confidencialidad frente al servidor, usar E2EE.
- **Monitorización:** alertar por certificados inválidos, ausencia de STARTTLS y caídas a texto claro, y revisar los registros del servidor.

Preguntas de análisis.

1. **¿Qué protege TLS y qué no protege?**

   TLS protege la confidencialidad e integridad de los datos en tránsito entre cliente y servidor, y autentica al servidor si el cliente valida la cadena. No protege los datos en reposo, los metadatos, los extremos comprometidos ni al operador del servidor; tampoco protege si el cliente desactiva la validación o acepta un certificado inválido, porque en ese caso un intermediario puede completar el handshake.

2. **¿En qué se diferencia el cifrado de transporte del cifrado de extremo a extremo?**

   El cifrado de transporte termina en el servidor: este descifra el mensaje para procesarlo y puede archivarlo o leerlo. El cifrado de extremo a extremo se aplica en el cliente y solo el destinatario puede descifrarlo; el servidor transporta texto cifrado y no puede leer el contenido, aunque sí observa metadatos como participantes y horarios. En el laboratorio, TLS protegió la captura de red, pero MAM conservó el mensaje en claro: esa es exactamente la diferencia.

Checklist de configuración TLS.. La Tabla 25 resume las verificaciones realizadas sobre ambos servidores.

Tabla 25
Checklist de configuración TLS del servidor XMPP

Verificación	Resultado	Evidencia / observación
Vigencia del certificado	Vencido / Válido	Inseguro: 2021-05-13 a 2022-05-13. Endurecido: hasta 2029.
Coincidencia del nombre (CN/SAN)	No / Sí	Inseguro: `CN=localhost`. Endurecido: `CN=lab.local` con SAN.
Cadena de confianza completa	No / Sí	Inseguro autofirmado; endurecido firmado por la CA local.
Versión de TLS negociada	TLS 1.3	Ambos servidores; TLS 1.0 y 1.1 rechazadas con alerta 70.
Suites de cifrado permitidas	AES-GCM	`TLS_AES_256_GCM_SHA384` en ambos.
Interfaz administrativa restringida	No / Sí	Inseguro escucha en ∗:5280 y 5281; endurecido en `127.0.0.1`.
Cifrado de extremo a extremo (E2EE)	No	No configurado; MAM conserva el cuerpo en claro.
Errores de negociación en los registros	Sí / No	Inseguro: `verify error 18` y `10`. Endurecido: `Verify return code 0`.

Conclusiones.

- Ambos servidores negocian TLS 1.3 y rechazan TLS 1.0/1.1; la debilidad del escenario inseguro está en el certificado, la autenticación en claro, el archivo MAM y la exposición administrativa.
- En la captura cifrada no se recuperan cuerpo ni contraseña; en la sesión sin TLS ambos aparecen en claro, incluida la credencial SASL `PLAIN`.
- El archivo MAM demuestra que TLS no protege frente al operador del servidor; se requiere cifrado de extremo a extremo para ese modelo de amenaza.
- La validación del certificado es decisiva: sin ella el handshake con un intermediario se completa; con validación se aborta.
- La regla de Suricata detectó el certificado autofirmado en TLS 1.2, pero no puede verlo en TLS 1.3, lo que subraya el valor de la telemetría del servidor y del endpoint.

- Las limitaciones incluyen el uso de una CA local, tráfico sintético y la ausencia de usuarios reales.

Tabla 26
Ficha de registro del hallazgo. Caso 10

Campo	Registro
Identificador	Caso 10 (XMPP y TLS), evidencias `01_topologia_lab.png` a `11_versiones_tls.png`. Analista: Yader Ibraldo Quiroga Torres.
Fecha y hora	10 de noviembre de 2026, 11:51–11:56 (UTC−5).
Origen/destino	Analista `172.28.50.10` hacia `172.28.50.30` (inseguro), `172.28.50.31` (endurecido) y el intermediario `172.28.50.10:4443`.
Observación	Certificado vencido y autofirmado, autenticación `PLAIN` sin TLS, mensaje en claro en MAM, MITM aceptado sin validación.
Hipótesis	Si TLS y la validación están bien configurados, el contenido no será recuperable de la captura y un certificado inválido será rechazado.
Validación	Cero coincidencias del cuerpo y la contraseña en la captura TLS; handshake con MITM abortado al validar; alerta de Suricata en TLS 1.2.
Severidad	Alta: exposición de credenciales y del historial de mensajes en el escenario inseguro.
Acción	Emitir certificado confiable, exigir TLS y autenticación cifrada, restringir administración, cifrar MAM y evaluar E2EE.
Integridad	`CU10_05`: `79c12243...e7c1c76`; `CU10_03`: `267df8e5...af1b66` (SHA-256 truncado; el valor completo está en el Anexo A).

7. Formato mínimo de registro por hallazgo

Cada hallazgo debe registrarse con los campos de la Tabla 27. El registro separa el hecho observado de la interpretación y exige indicar la evidencia que permitió validar o descartar la hipótesis. El formato es obligatorio para los diez casos y se complementa con la ficha de cada caso.

Tabla 27
Formato mínimo de registro por hallazgo

Campo	Qué registrar
Identificador	Caso, número de evidencia y nombre del analista.
Fecha/hora	Marca temporal y zona horaria; sincronización conocida.
Origen/destino	IP, MAC cuando sea pertinente, puertos y protocolo; anonimizar si aplica.
Observación	Hecho directamente observado, sin conclusiones prematuras.
Hipótesis	Explicación posible y alternativas benignas consideradas.
Validación	PCAP o registro consultado, filtro, comandos de inspección y resultado.
Severidad	Impacto, probabilidad y justificación.
Acción	Medida propuesta, responsable, riesgo de falsos positivos y verificación.
Integridad	Nombre de archivo, tamaño y hash SHA-256 de la evidencia original.

Consolidado de hallazgos. Use la Tabla 28 para mantener la trazabilidad entre los casos y el informe final. Los hashes y la cadena de custodia se registran en el Anexo A.

Tabla 28
Consolidado de hallazgos de la Parte I

No.	Caso	Fecha/hora	Origen/destino	Observación	Severidad	Acción

Regla de evidencia

Una anomalía no es una prueba de ataque. Antes de asignar severidad, confirme la observación con al menos dos fuentes independientes (por ejemplo, PCAP y registro del servidor) y documente las explicaciones benignas que no se pudieron descartar. Si la evidencia es insuficiente, indíquelo como limitación. La conservación y el análisis de la evidencia siguen las recomendaciones de gestión de incidentes de Cichonski et al. (2012).

8. Entregables de la Parte I

El equipo debe entregar un informe técnico con los siguientes componentes. Marque cada entregable cuando esté completo y verificable.

- ☐ Informe técnico por equipo, con resumen ejecutivo y alcance del laboratorio.
- ☐ Diez fichas de caso con indicadores, análisis, hipótesis alternativas y medidas de defensa.
- ☐ Capturas de pantalla legibles y PCAP didácticas o sintéticas cuando corresponda, con hash SHA-256.

- [ ] Reglas de detección propuestas y justificadas; no se exige activar bloqueos automáticos en producción.
- [ ] Conclusiones sobre los límites de la evidencia y oportunidades de mejora.
- [ ] Anexo de evidencias con nombre de archivo, tamaño, fecha y hash SHA-256.
- [ ] Tabla de distribución del trabajo y lista de verificación firmada por los cuatro integrantes.

8.1. Criterios de calidad del informe

- **Reproducibilidad:** cada resultado debe poder repetirse con el filtro, comando o script indicado.
- **Trazabilidad:** toda afirmación debe remitir a una evidencia identificada y a una marca de tiempo.
- **Legibilidad:** las capturas deben permitir leer direcciones, puertos, filtros y marcas de tiempo.
- **Anonimización:** no deben aparecer datos personales, credenciales ni direcciones de terceros.
- **Integridad:** la evidencia original se conserva sin modificaciones y se analiza sobre una copia de trabajo.
- **Postura crítica:** se deben reconocer los falsos positivos, las limitaciones y las hipótesis no confirmadas.

Parte II. Programación

9. Descripción y alcance de la solución

La Parte II propone una aplicación, programa o bot que permita registrar un número telefónico, solicitar la ubicación del dispositivo asociado y visualizarla en un mapa, en tiempo real o por intervalos. La solución debe operar con consentimiento informado del usuario y con datos anonimizados; el objetivo es académico y no comercial.

Tabla 29
Niveles de viabilidad del rastreo según el servicio

Servicio	Fuente de ubicación	Viabilidad y límites	Requisito de consentimiento
WhatsApp	Ubicación compartida manualmente	Limitada e indirecta: la aplicación no expone la ubicación en tiempo real ni permite rastrear a un contacto sin su acción.	El usuario debe compartir su ubicación de forma explícita.
Telegram	Bot y ubicación enviada por el usuario	Un bot puede solicitar la ubicación mediante botones, pero no puede rastrear automáticamente sin que el usuario la envíe.	El usuario debe iniciar el chat y autorizar el envío.
Celular directamente	GPS del dispositivo	Requiere una aplicación instalada en el dispositivo objetivo y permisos de localización.	Consentimiento expreso durante la instalación y uso.

9.1. Alcance propuesto

- Prototipo funcional con registro por número telefónico, autenticación y visualización de ubicaciones en un mapa.
- Actualización periódica de la ubicación, con intervalo configurable (por ejemplo, cada 10 minutos).
- Historial de ubicaciones y, como funcionalidad opcional, alertas por geofencing.
- Documentación técnica, modelo de datos, API, plan de pruebas y análisis de riesgos.
- Demostración con datos sintéticos o de laboratorio; no se utilizarán personas reales ni dispositivos de terceros.

9.2. Fuera de alcance

- Rastrear personas sin consentimiento, interceptar comunicaciones o vulnerar la seguridad de WhatsApp, Telegram o de un operador móvil.
- Utilizar APIs no oficiales, ingeniería inversa o técnicas que incumplan los términos de servicio de las plataformas.

- Almacenar datos personales reales, credenciales o ubicaciones de terceros en el repositorio o en el informe.
- Automatizar bloqueos, decisiones disciplinarias o acciones sobre personas a partir de una puntuación de riesgo.

Principio de diseño

La solución debe pedir la ubicación, no tomarla por la fuerza. El usuario objetivo debe conocer quién recibe sus datos, para qué se usan, durante cuánto tiempo se conservan y cómo puede revocar el consentimiento.

10. Requisitos funcionales

La Tabla 30 recoge los requisitos funcionales mínimos del sistema. El equipo debe completar la prioridad, el criterio de aceptación y el estado de implementación.

Tabla 30
Requisitos funcionales de la solución

Código	Requisito	Descripción	Prioridad	Criterio de aceptación
RF-01	Registro por número telefónico	El sistema debe registrar y vincular dispositivos a través del número telefónico.	Alta	
RF-02	Solicitud y captura de ubicación	Permitir al usuario objetivo enviar su ubicación actual o automática.	Alta	
RF-03	Actualización periódica	Capturar la ubicación del dispositivo cada intervalo definido (por ejemplo, cada 10 minutos).	Media	
RF-04	Visualización en mapa	Mostrar la ubicación en un mapa integrado (Google Maps, OpenStreetMap u otro).	Alta	
RF-05	Alertas (opcional)	Alertar si el dispositivo entra o sale de una zona geográfica (geofencing).	Baja	
RF-06	Historial de ubicaciones	Guardar y consultar ubicaciones pasadas por fecha y hora.	Alta	
RF-07	Acceso seguro	Autenticar al usuario y autorizar el acceso a las ubicaciones propias o compartidas.	Alta	

11. Requisitos técnicos

La solución se compone de una aplicación móvil, un bot opcional, un backend con API REST, una base de datos y una capa de visualización. La Tabla 31 resume los componentes y las tecnologías sugeridas.

Tabla 31
Componentes técnicos y tecnologías sugeridas

Componente	Requisito técnico	Tecnología sugerida	Versión	Estado
Aplicación móvil	Captura GPS y envío periódico de coordenadas.	Android/iOS nativo o Flutter/React Native.		
Bot de Telegram	Solicitud manual de ubicación y autorización del usuario.	Bot API de Telegram.		
Backend	API REST para registrar usuarios y recibir ubicaciones.	Python, Node.js, PHP o similar.		
Base de datos	Persistencia de usuarios, dispositivos, ubicaciones y consentimientos.	PostgreSQL, MongoDB o Firebase.		
Autenticación	Registro y acceso por número y token.	JWT, OAuth 2.0 o sesiones seguras.		
Mapa	Visualización y geocodificación inversa.	Google Maps, Mapbox o Leaflet.js.		

11.1. Aplicación móvil

- Aplicación Android/iOS instalada en el dispositivo objetivo.
- Solicitud de permisos de GPS y localización en el momento de la instalación o del primer uso.
- Envío periódico de coordenadas al servidor (backend).
- Vinculación con el número telefónico mediante SMS o código de verificación.
- Indicador visible de que la ubicación se está compartiendo y opción de detenerla.

11.2. Bot en Telegram (opcional)

- El bot puede solicitar la ubicación manual mediante botones.
- No puede rastrear automáticamente sin que el usuario envíe su ubicación.
- Requiere que el usuario inicie el chat y autorice el envío.

- El bot debe informar la finalidad, el tiempo de retención y la forma de revocar el consentimiento.

11.3. Backend y API REST

- Lenguaje: Python, Node.js, PHP o similar.
- API REST para enviar y recibir ubicaciones, con versionado y documentación OpenAPI.
- Base de datos: PostgreSQL, MongoDB o Firebase.
- Sistema de autenticación por número y token, con expiración y revocación.
- Registros de auditoría para accesos, consultas y cambios de consentimiento.

11.4. Mapa y visualización

- API de Google Maps, Mapbox o Leaflet.js para mostrar las ubicaciones.
- Soporte para geocodificación inversa (coordenadas a dirección).
- Marcas con fecha y hora, historial por intervalo y control de acceso por usuario.

11.5. Requisitos de seguridad y privacidad

Tabla 32
Requisitos de seguridad y privacidad de la solución

Código	Requisito	Implementación propuesta	Verificación
RS-01	Cifrado en tránsito	TLS 1.2 o superior en todas las comunicaciones con la API y el bot.	
RS-02	Protección de credenciales	Hash de contraseñas con Argon2, bcrypt o scrypt; nunca almacenar texto claro.	
RS-03	Sesiones y tokens	Tokens con expiración, rotación y revocación; almacenamiento seguro en el cliente.	
RS-04	Control de acceso	Cada usuario solo puede consultar sus dispositivos y ubicaciones autorizadas.	
RS-05	Limitación de tasa	Límites por usuario, dispositivo e IP para evitar abuso y enumeración.	
RS-06	Validación de entradas	Validar y normalizar números, coordenadas, fechas y parámetros de la API.	
RS-07	Cifrado en reposo	Cifrar la base de datos y las copias de seguridad; gestionar claves fuera del código.	
RS-08	Auditoría	Registrar accesos, consultas, cambios de consentimiento y errores de seguridad.	
RS-09	Consentimiento	Registro explícito, fecha, alcance, finalidad y revocación del consentimiento.	
RS-10	Minimización y retención	Recolectar solo los datos necesarios y definir plazos de conservación y borrado.	

12. Arquitectura de referencia

La arquitectura de referencia separa la captura de ubicación, la autenticación, el almacenamiento y la visualización. La Figura 44 es un espacio para que el equipo incluya su diagrama; la Tabla 33 describe las responsabilidades de cada componente.



Figura 44

Arquitectura de referencia de la solución

Tabla 33

Componentes de la arquitectura y responsabilidades

Componente	Función	Entrada	Salida	Tecnología
Aplicación móvil	Captura y envía la ubicación con consentimiento.	GPS, usuario	Coordenadas, estado	
Bot de Telegram	Solicita la ubicación de forma manual.	Comando del usuario	Coordenadas	
API REST	Valida, autentica y registra las solicitudes.	Peticiones HTTPS	Respuestas JSON	
Autenticación	Verifica identidad y permisos.	Número, token	Sesión / JWT	
Base de datos	Persiste usuarios, dispositivos, ubicaciones y consentimientos.	Datos validados	Consultas	
Servicio de mapas	Representa las ubicaciones y resuelve direcciones.	Coordenadas	Mapa / dirección	
Panel administrativo	Consulta y audita el sistema.	Credenciales	Reportes	

13. Modelo de datos propuesto

La Tabla 34 propone las entidades mínimas. El equipo debe ajustar los campos a su implementación y documentar las claves primarias, foráneas e índices.

Tabla 34
Entidades y campos principales del modelo de datos

Entidad	Campos principales	Relaciones
Usuario	Identificador, nombre, número telefónico, correo, hash de contraseña, estado.	Uno a muchos con dispositivos y consentimientos.
Dispositivo	Identificador, usuario, número, plataforma, token, estado.	Muchos a uno con usuario; uno a muchos con ubicaciones.
Ubicación	Identificador, dispositivo, latitud, longitud, precisión, fecha/hora, fuente.	Muchos a uno con dispositivo.
Consentimiento	Identificador, usuario, finalidad, alcance, fecha, estado, fecha de revocación.	Muchos a uno con usuario.
Zona	Identificador, usuario, nombre, centro, radio.	Uno a muchos con alertas.
Alerta	Identificador, zona, dispositivo, tipo, fecha, estado.	Muchos a uno con zona y dispositivo.

14. Plan de trabajo

El plan de la Tabla 35 distribuye las tres semanas del taller. Ajuste las fechas y los responsables según la disponibilidad del equipo; conserve los hitos de revisión y la entrega final.

Tabla 35
Plan de trabajo sugerido

Semana	Fechas	Actividades	Entregable	Responsable
1	26 oct – 1 nov	Marco del laboratorio, topología, casos 1 a 3 y diseño inicial de la Parte II.	Fichas 1–3 y propuesta inicial.	
2	2 – 8 nov	Casos 4 a 7, arquitectura, modelo de datos y API.	Fichas 4–7 y arquitectura.	
3	9 – 14 nov	Casos 8 a 10, implementación, pruebas, informe final y hashes.	Versión final y anexos.	

15. Entregables de la Parte II

□ Código fuente funcional en un repositorio con historial de commits.

□ README con requisitos, instalación, configuración, ejecución y pruebas.

□ Diagrama de arquitectura y modelo de datos.

□ Documentación de la API REST (OpenAPI o equivalente).

□ Demostración con datos sintéticos o de laboratorio (video, capturas o ejecución en vivo).

□ Plan de pruebas y resultados de los casos felices y de error.

□ Política de privacidad, consentimiento informado y mecanismo de revocación.

□ Análisis de riesgos, limitaciones y trabajo futuro.

16. Consideraciones éticas, legales y de privacidad

El diseño y la implementación de la solución deben cumplir los principios de consentimiento, finalidad, minimización, seguridad y transparencia. En Colombia, el tratamiento de datos personales se rige, entre otras normas, por la Ley 1581 de 2012 (Congreso de la República de Colombia, 2012). La ubicación geográfica es un dato personal y su tratamiento requiere autorización previa, expresa e informada del titular, salvo las excepciones legales.

16.1. Principios de tratamiento

- **Consentimiento informado:** el usuario debe conocer quién recibe la ubicación, para qué, durante cuánto tiempo y cómo revocar la autorización.
- **Finalidad limitada:** los datos solo se usan para el propósito académico declarado; no se reutilizan para marketing, vigilancia o perfilamiento.
- **Minimización:** se recolectan únicamente los datos necesarios; se evita la ubicación continua cuando basta una captura periódica.
- **Seguridad:** TLS en tránsito, cifrado en reposo, control de acceso, tokens con expiración y registros de auditoría.
- **Retención y borrado:** se define un plazo de conservación y un mecanismo de eliminación verificable.
- **Transparencia:** el usuario puede consultar qué datos se almacenan, corregirlos y solicitar su eliminación.

- **No discriminación:** la ubicación no se usa para tomar decisiones automatizadas sobre personas.

16.2. Prohibiciones explícitas

- Rastrear a una persona sin su consentimiento o mediante engaño, coerción o suplantación.
- Interceptar comunicaciones, vulnerar plataformas o usar APIs no oficiales.
- Compartir ubicaciones con terceros no autorizados o publicarlas en el repositorio.
- Usar los datos para vigilar, acosar, discriminar o tomar represalias.
- Delegar en un modelo de IA la decisión de bloquear, sancionar o exponer a una persona.

Nota del taller

El taller no solicita vulnerar, atacar ni hackear escenarios domésticos o empresariales reales. El ejercicio es académico y los participantes deben actuar como profesionales de seguridad: sin causar daño intencional a sistemas, redes o personas, y sin usar técnicas que comprometan la integridad de sistemas reales sin autorización expresa de sus propietarios.

16.3. Matriz de riesgos éticos y legales

Tabla 36
Riesgos éticos y legales de la solución

Riesgo	Impacto	Medida de mitigación
Rastreo sin consentimiento	Alto	Consentimiento explícito, registro de fecha y revocación; bloqueo del servicio sin autorización.
Exposición de ubicaciones	Alto	Cifrado, control de acceso, minimización y auditoría de consultas.
Uso secundario de los datos	Medio	Política de finalidad limitada y prohibición de reutilización.
Retención excesiva	Medio	Plazo de conservación definido y borrado programado.
Acceso no autorizado	Alto	Autenticación fuerte, tokens con expiración y principio de mínimo privilegio.
Sesgo o error del modelo	Medio	Revisión humana, métricas de falsos positivos y explicabilidad.

17. Conclusiones

Las conclusiones deben sintetizar los hallazgos, reconocer las limitaciones de la evidencia y proponer un plan de mejora priorizado. No repita el procedimiento de cada caso: interprete qué

demuestra la evidencia, qué no demuestra y qué control reduce el riesgo.

Tabla 37
Síntesis de hallazgos y controles por caso

Caso	Hallazgo principal	Evidencia que lo sustenta	Control recomendado	Limitación
1				
2				
3				
4				
5				
6				
7				
8				
9				
10				

17.1. Conclusiones de la Parte I

[Redacte entre tres y cinco párrafos. Indique qué patrones se repitieron entre casos, qué controles tuvieron mayor impacto y qué indicadores resultaron más fiables. Diferencie los hallazgos confirmados de las hipótesis no resueltas.]

17.2. Conclusiones de la Parte II

[Explique qué solución se propuso, por qué es viable, qué requisitos de seguridad y privacidad se priorizaron y qué límites tiene el prototipo. Diferencie el rastreo con consentimiento del rastreo encubierto y justifique por qué este último queda fuera del alcance.]

17.3. Limitaciones y trabajo futuro

- **Limitaciones de la evidencia:** tamaño de las capturas, tráfico sintético, ausencia de algunos registros, relojes no sincronizados o datos anonimizados que impiden reproducir el contexto.
- **Limitaciones del prototipo:** cobertura de dispositivos, precisión del GPS, disponibilidad de APIs, consumo de batería y dependencia de servicios de terceros.
- **Trabajo futuro:** ampliar la línea base, automatizar la correlación con reglas explicables, evaluar la deriva del modelo, incorporar pruebas de carga y mejorar los mecanismos de consentimiento y borrado.

Referencias

Cichonski, P., Millar, T., Grance, T., & Scarfone, K. (2012). *Computer Security Incident Handling Guide* (Special Publication N.º 800-61 Rev. 2). National Institute of Standards and Technology. https://csrc.nist.gov/pubs/sp/800/61/r2/final

Congreso de la República de Colombia. (2012). Ley 1581 de 2012, por la cual se dictan disposiciones generales para la protección de datos personales. https://www.funcionpublica.gov.co/eva/gestornormativo/norma.php?i=49981

Lyon, G. (2026). Nmap Reference Guide. https://nmap.org/book/man.html

Mockapetris, P. (1987). Domain Names—Implementation and Specification. https://doi.org/10.17487/RFC1035

OWASP Foundation. (2021). OWASP Top 10:2021—The Ten Most Critical Web Application Security Risks. https://owasp.org/Top10/

Postel, J. (1981). Internet Control Message Protocol. https://doi.org/10.17487/RFC0792

Rescorla, E. (2018). The Transport Layer Security (TLS) Protocol Version 1.3. https://doi.org/10.17487/RFC8446

Saint-Andre, P. (2011). Extensible Messaging and Presence Protocol (XMPP): Core. https://doi.org/10.17487/RFC6120

Scarfone, K., Jansen, W., & Tracy, M. (2008). *Guide to General Server Security* (Special Publication N.º 800-123). National Institute of Standards and Technology. https://csrc.nist.gov/pubs/sp/800/123/final

Scarfone, K., & Mell, P. (2007). *Guide to Intrusion Detection and Prevention Systems (IDPS)* (Special Publication N.º 800-94). National Institute of Standards and Technology. https://csrc.nist.gov/pubs/sp/800/94/final

Scikit-learn developers. (2026). Scikit-learn: Machine Learning in Python. https://scikit-learn.org/stable/

Wireshark Foundation. (2026). Wireshark User's Guide. https://www.wireshark.org/docs/wsug_html_chunked/

Anexos

Anexo A. Registro de evidencias y cadena de custodia

La Tabla 38 reproduce el registro de integridad de las capturas. Conserve la copia original sin modificaciones, analice una copia de trabajo y verifique el SHA-256 antes de abrirla; el manifiesto completo está en `laboratorio/evidencias_sha256.txt`.

Tabla 38

Registro de evidencias y cadena de custodia

Archivo	Tipo	Tamaño	Fecha/hora	SHA-256	Analista
`CU7_01_baseline_icmp.pcap`	PCAP	936 B	2026-11-10 11:47	`c3af28d1df0ac1a248bd6361f8a7898e e241a1cf5fb4d827c87643e5268caee5`	Yader Ibraldo Quiroga Torres
`CU7_02_icmp_sweep.pcap`	PCAP	4.896 B	2026-11-10 11:47	`95c75cdfd7b4be61f00493ba50ade17c 5b03c6ec9dbf3051a7b289f829273c2d`	Yader Ibraldo Quiroga Torres
`CU7_03_icmp_tunnel.pcap`	PCAP	28.764 B	2026-11-10 11:47	`7d32a148c00de6aa0a98d03aab3954d6 e44e1d805a1370ade2250c813c111c8c`	Yader Ibraldo Quiroga Torres
`CU8_01_syn_scan.pcap`	PCAP	147.776 B	2026-11-10 11:58	`9fef801cadf8b5f1cc0cfe0496f8999c cd05dc6fb2a1a09220a4e194b555130c`	Yader Ibraldo Quiroga Torres
`CU8_02_service_scan.pcap`	PCAP	395.648 B	2026-11-10 11:58	`41a5fab713dbf711276a8f6098a87c4e 16e033db05c25ef31fe32f5316bf5a09`	Yader Ibraldo Quiroga Torres
`CU8_03_udp_scan.pcap`	PCAP	3.616 B	2026-11-10 11:58	`f1f094daf14a5bcfc7b31e8deb75f4a1 57122134e0747168d8bc4ddd36bbb89d`	Yader Ibraldo Quiroga Torres
`CU10_01_xmpp_insecure.pcap`	PCAP	5.105 B	2026-11-10 11:51	`3400d740daf0d9f3d75fe6ccdc69d23f 24e0984a6ec67ebfa0a1853095b87bda`	Yader Ibraldo Quiroga Torres
`CU10_02_xmpp_secure.pcap`	PCAP	5.362 B	2026-11-10 11:51	`3e2f0b6938aa4b06bcd9e1762c4183db 5471acaf3b87603198394e902b6fef6d`	Yader Ibraldo Quiroga Torres
`CU10_03_xmpp_message.pcap`	PCAP	21.373 B	2026-11-10 11:52	`267df8e580e63a9f0202be4667ba0500 1b8ac695b05b56c18edf288f4eaf1b66`	Yader Ibraldo Quiroga Torres
`CU10_05_xmpp_plaintext.pcap`	PCAP	4.346 B	2026-11-10 11:52	`79c12243f3a5fcf51694e7edf355e2cb 80d2fc52bf8c1e535b15e11ebe7c1c76`	Yader Ibraldo Quiroga Torres
`CU10_06_https_insecure.pcap`	PCAP	9.319 B	2026-11-10 11:54	`62315796d2ba7687ad3247b2d9b0d176 838924bec228622e94ebb27773e86dad`	Yader Ibraldo Quiroga Torres
`CU10_07_https_tls12_insecure.pcap`	PCAP	8.442 B	2026-11-10 11:55	`163f557c1cd60c86efbc7c259caeaa2e ade2ae6c973ae32b35db8fff1a5479ea`	Yader Ibraldo Quiroga Torres
`CU10_08_https_tls12_secure.pcap`	PCAP	8.864 B	2026-11-10 11:55	`5679faae98540281908ff5e6fbddbda5 d2b8e2e7aedc9f085fb354dc3f331afa`	Yader Ibraldo Quiroga Torres

Anexo B. Lista de verificación de entrega

Tabla 39
Lista de verificación de entrega

Entregable	¿Incluido?	Observaciones	Responsable
Informe técnico con resumen ejecutivo y alcance.	☐		
Diez fichas de caso completas.	☐		
Capturas legibles y PCAP de laboratorio.	☐		
Hashes SHA-256 y cadena de custodia.	☐		
Reglas de detección propuestas.	☐		
Conclusiones y limitaciones.	☐		
Código fuente y README de la Parte II.	☐		
Diagrama de arquitectura y modelo de datos.	☐		
Demostración con datos sintéticos.	☐		
Política de privacidad y consentimiento.	☐		

Anexo C. Glosario

Tabla 40
Términos frecuentes del taller

Término	Definición
Anomalía	Desviación observable respecto de una línea base o comportamiento esperado.
E2EE	Cifrado de extremo a extremo: solo los participantes pueden leer el contenido.
Falso positivo	Alerta que señala un comportamiento legítimo como si fuera malicioso.
Geofencing	Definición de una zona geográfica y generación de alertas al entrar o salir de ella.
Hash SHA-256	Huella digital de 256 bits que permite verificar la integridad de un archivo.
IDS / IPS	Sistema de detección / prevención de intrusiones.
IOC	Indicador de compromiso: señal observable que sugiere actividad maliciosa.
MITM	Ataque de intermediario que intercepta o modifica una comunicación.
PCAP	Archivo de captura de paquetes de red.
SIEM	Plataforma de correlación y gestión de eventos e incidentes de seguridad.
TLS	Protocolo de seguridad para el transporte de datos en red.